AMANE — Refonte V3

Faire d'AMANE une enveloppe d'exécution souveraine pour SaaS externes

Journal de refonte, décisions d'architecture et tri du dépôt

Version	2.8
Date	2026-11-05
Branche	main3
Statut	Étapes 1 à 9 terminées — étape 10 (images, relais) avant le banc

Sommaire

Fiche du document 4

Historique des versions . . . 4

1. Objet de la refonte 6

1.1 Ce qu'est une « enveloppe d'exécution » . . . 6

1.2 La promesse à tenir . . . 6

2. État actuel du dépôt (V2, point de départ) 7

2.1 Point de départ figé . . . 7

2.2 Cartographie des composants . . . 7

2.3 Trois constats qui orientent le tri . . . 7

3. Décisions d'architecture 9

ADR-001 — Haute disponibilité PME : etcd + Patroni piloté par l'orchestrateur Go . . . 9

ADR-002 — Formats d'exécutables acceptés . . . 10

ADR-003 — Zero-knowledge strict . . . 10

ADR-004 — Modalités de la haute disponibilité PME . . . 11

ADR-005 — Installation de la pile HA chez la PME . . . 12

ADR-006 — Réglages de bascule . . . 13

ADR-007 — Hébergement de l'application externe . . . 13

ADR-008 — Confinement et chiffrement . . . 14

ADR-009 — Catalogue des applications hébergées . . . 15

ADR-010 — Récupération de la DEK après perte totale . . . 16

ADR-011 — Jeton du relais propre à chaque tenant et sauvegardes liées à leur nom . . . 17

4. Tri du dépôt 19

4.1 À garder intact . . . 19

4.2 À garder mais adapter . . . 19

4.3 À supprimer . . . 20

5. Plan de travail par étapes 21

6. Journal des étapes 23

Étape 0 — Préparation (2026-10-28) . . . 23

Étape 1 — Nettoyage (2026-10-28) . . . 23

Étape 1 — Compléments (2026-10-28) . . . 24

Étape 2a — Image de l'orchestrateur et laboratoire HA (2026-10-28) . . . 24

Étape 2b — Pile PME réelle (2026-10-29) . . . 28

Méthode de travail à partir du 2026-10-29 . . . 31

Étape 2c — Recentrage du nœud Rust (2026-10-29) . . . 31
Étape 2d — Réplication synchrone, alerte et mesures (2026-10-29) . . . 32
Étape 3 — Le nœud, hôte d'exécution (2026-10-29) . . . 33
Étape 4 — Confinement et chiffrement (2026-10-29) . . . 34
Étape 5 — Catalogue des applications du SaaS éditeur (2026-10-29) . . . 35
Étape 6 — Console React (2026-10-29) . . . 35
Étape 7 — Documentation (2026-10-29) . . . 36
Bilan des étapes 1 à 7 . . . 37
Séance du 2026-10-29 (après-midi) — publication et analyse de ce qui reste . . . 37
Séance du 2026-11-04 — préparation de l'essai d'une application hébergée . . . 41
Faille corrigée le 2026-11-04 — l'application hébergée lisait les secrets du cluster . . . 42
Étape 8 — Récupération de la DEK après perte totale (2026-11-04) . . . 44
Étape 9 — Jeton du relais et sauvegardes liées à leur nom (2026-11-05) . . . 46

7. Points ouverts **48**

Annexe — Mettre à jour ce document **50**

Annexe — Validation sur le banc AMANE Test (étapes 2b à 4) **51**

Fiche du document

Ce document est le **journal de bord de la refonte V3** d'AMANE. Il récapitule l'état du dépôt au départ, le tri de chaque composant (garder intact, adapter, supprimer), les décisions d'architecture prises et leur justification, puis l'avancement étape par étape. Il sert de référence aux collaborateurs pour comprendre **ce qui a été fait, pourquoi, et dans quel ordre**.

Il est mis à jour à chaque étape de la refonte. La source fait foi (`docs/refonte-v3/AMANE-Refonte-V3.md`) ; le PDF est régénéré à partir d'elle (voir l'annexe « Mettre à jour ce document »).

Historique des versions

Version	Date	Branche / commit	Changements
1.0	2026-10-28	main3 / 6da5022	Création : état V2, tri initial, décisions ADR-001 à ADR-003, plan par étapes
1.1	2026-10-28	main3 / dc06197	Étape 1 (nettoyage) terminée ; tri corrigé (§ 4.3) ; points à vérifier ajoutés (§ 7)
1.2	2026-10-28	main3	Compléments à l'étape 1 : compilation Rust confirmée, test de réplication corrigé, test V1 `mock_server.rs` retiré ; réplication synchrone ajoutée à ADR-001 et à l'étape 2
1.3	2026-10-28	main3	ADR-004 (modalités de la HA PME, 7 décisions) ; `quorum.rs` réorienté plutôt que supprimé ; étape 2 découpée en 2a à 2d
1.4	2026-10-28	main3	Sous-étape 2a : image de l'orchestrateur, laboratoire HA trois machines, 10 scénarios de chaos réussis, 3 défauts de l'orchestrateur corrigés
1.5	2026-10-28	main3	ADR-005 (installation de la pile HA chez la PME, 5 décisions) ; défaut zero-knowledge des mots de passe dérivés du jeton
1.6	2026-10-29	main3 / 08fa0a3	Sous-étape 2b : pile PME générée (serveur, témoin), amorçage etcd, secrets locaux, HAProxy, images épinglées ; essai sur trois machines réussi ; procédure du banc
1.7	2026-10-29	main3	Sous-étape 2c : nœud Rust recentré (garde de quorum en lecture, époque = timeline, fencing continu) ; méthode de travail : étapes enchaînées, commit par étape sans push
1.8	2026-10-29	main3	Sous-étape 2d : mode synchrone selon la taille du cluster, alerte « sous le seuil », mesures ; ADR-006 ; essai sur trois machines 13/13
1.9	2026-10-29	main3	Étape 3 : le nœud héberge une application externe (manifeste, lanceur, base dédiée, reverse proxy) ; ADR-007
2.0	2026-10-29	main3	Étape 4 : réseau de l'application sans sortie, enrôlement des serveurs par code à usage unique, sauvegardes chiffrées sur le relais, chiffrement du disque vérifié ; ADR-008 ; routes de blobs du relais corrigées
2.1	2026-10-29	main3	Étape 5 : catalogue des applications hébergées (modèle, validation contre le registre, rattachement à la licence) ; ADR-009 ; contrat d'API à jour des champs V3
2.2	2026-10-29	main3	Étape 6 : console React — page Applications, application rattachée aux licences, états V3 des machines, page Architecture réécrite pour la V3
2.3	2026-10-29	main3	Étape 7 : documentation V3 (README, CLAUDE.md, accès, architecture, agents IA), `pme-deploy/` retiré ; absence de récupération de la DEK en cas de perte totale identifiée comme premier point ouvert ; procédure du banc complétée

Version	Date	Branche / commit	Changements
2.4	2026-10-29	main3	Étapes 1 à 7 poussées sur `origin/main3` ; parcours de bout en bout V3 ; analyse de la récupération de la DEK (briques du socle, manques, Shamir maison) et proposition ; jeton du relais et blobs non liés à leur nom ; étapes 8 à 11 avant le banc ; images V3 reconstruites et publiées
2.5	2026-11-04	main3	Étape 11 en partie : banc sur Tailscale, adresse des machines prise sur la route vers le portail (installeurs Linux et Windows), chaîne de soumission d'une application vérifiée de bout en bout côté éditeur avec l'application d'exemple ; démarche de soumission confirmée (image et manifeste, ADR-009) ; application de gestion de stock et de facturation attendue de l'équipe
2.6	2026-11-04	main3	Faille corrigée : l'application hébergée lisait les secrets du cluster (mot de passe du superutilisateur PostgreSQL) ; volume `secrets-application` dédié, orchestrateur republié ; test Go qui rejoignait l'etcd de développement corrigé ; procédure de test V3 sur 5 machines ; refus de licence sans effet sur le cluster ajouté aux points ouverts
2.7	2026-11-04	main3	ADR-010 et étape 8 : récupération de la DEK après perte totale (passphrase du gérant et parts papier, Shamir par vsss-rs à la place du code maison, garde-fou, protection des anciennes sauvegardes) ; régression de la sauvegarde de la base `application` corrigée
2.8	2026-11-05	main3	Étapes 1 à 8 poussées sur `origin/main3` ; ADR-011 et étape 9 : jeton du relais propre à chaque tenant (HMAC d'un secret partagé entre portail et relais), exigé pour les blobs et la topologie ; relais qui refuse de démarrer sans secret ; sauvegardes liées à leur nom (tenant, base, date authentifiés)

1. Objet de la refonte

1.1 Ce qu'est une « enveloppe d'exécution »

Jusqu'en V2, AMANE embarquait sa propre application métier (gestion de stock) au-dessus de son socle de souveraineté. La V3 inverse la logique : **AMANE devient l'enveloppe dans laquelle s'exécute un SaaS édité par un tiers**.

- Un éditeur externe soumet l'**exécutable** de son SaaS à AMANE (en priorité une image Docker).
- AMANE le déploie sur le cluster de la PME et en assure l'**orchestration** : haute disponibilité, réplication, bascule, réseau, sauvegarde.
- Le SaaS s'exécute **sur la base de l'architecture AMANE** : ses données restent chez la PME et ne sortent que chiffrées.
- L'**interface utilisateur et la couche métier du SaaS ne changent pas**. L'utilisateur final retrouve exactement l'application qu'il connaît ; l'éditeur externe n'a pas à réécrire son code ni à intégrer un SDK.

1.2 La promesse à tenir

> **Personne d'autre que la PME ne voit de données en clair. La DEK et toutes les clés de chiffrement restent dans le cluster PME. Ni l'éditeur AMANE, ni le relais, ni l'éditeur du SaaS externe n'ont accès au clair.**

Cette promesse est le cœur d'AMANE ; toute décision de la refonte est évaluée à son aune.

2. État actuel du dépôt (V2, point de départ)

2.1 Point de départ figé

- Branche de travail créée : `main3`, à partir de `main2` (commit `e0f6d09`), poussée sur `origin/main3`.
- Le travail V2 non commité (76 fichiers) a été figé dans le commit `6da5022` « chore: état V2 avant nettoyage ». C'est le point de retour de référence avant toute suppression.

2.2 Cartographie des composants

Composant	Chemin	Rôle en V2
SaaS éditeur (Django)	`config/`, `tenants/`, `licenses/`, `devices/`, `dashboard/`, `api/`, `templates/`	Comptes tenants, licences, parc installé, génération des installeurs PME
Console web (React)	`frontend/`	Console éditeur et espace tenant, consomme l'API DRF
Orchestrateur cluster (Go)	`orchestrator-go/`	etcd v3, Patroni, réplication CRDT, mesh WireGuard, serveur gRPC mTLS
Socle crypto et journal (Rust)	`spike/crates/ss-crypto`, `ss-journal`, `ss-consensus`	AK/DEK, CRL, Shamir, journal CBOR chiffré, époque et fencing, garde de quorum
SDK client métier (Rust)	`core-rust/ss-client/`	Invariants stock, mode hors-ligne, appairage, licence, client gRPC
Nœud PME (Rust)	`spike/node/`	CLI, supervision PostgreSQL, annonce au relais, **application stock et utilisateurs intégrée**
Relais zero-knowledge (Rust)	`spike/relay/`, `relay-deploy/`	Stockage de blobs opaques et topologie du cluster
Contrat gRPC	`proto/amane/framework/v1/framework.proto`	Interface unique B ↔ C (Ping, Enroll, Write, Read, NotifyRevocation, PushDelta)
Déploiement PME	`pme-deploy/`, `templates/tenants/*.tmpl`	PostgreSQL primaire/standby + nœud + pgAdmin + watchtower
CI et mesures	`.github/workflows/`, `.ci/`, `scripts/`, `tests/`, `docs/bench/`	Build, couverture, chaos, contrats, benchmarks, mesures de bascule

2.3 Trois constats qui orientent le tri

Constat 1 — Deux mécanismes de haute disponibilité coexistent. L'orchestrateur Go (etcd + Patroni) n'est utilisé que dans le `docker-compose.yml` de développement et dans la CI. La pile réellement déployée chez la PME n'en contient pas : elle repose sur une réplication streaming PostgreSQL nue et sur le nœud Rust, qui décide seul de la promotion d'un standby (`spike/crates/ss-consensus/src/quorum.rs`, élection déterministe par LSN). Cette élection écrite à la main est en tension avec la règle n° 2 du projet (« aucun algorithme de consensus écrit à la main »).

Constat 2 — Le nœud PME embarque sa propre application métier. Le module `spike/node/src/stock/` et les pages HTML associées (articles, utilisateurs, tableau de bord) constituent une application métier complète. C'est précisément le rôle que tiendra désormais le SaaS externe.

Constat 3 — La console éditeur existe en double. Une version rendue côté serveur par Django (`templates/*.html`, `views_web.py`, `views.py`) et une version React (`frontend/`) couvrent les mêmes

écrans.

Autres observations : le nœud déclare la dépendance `ss-client` dans le workspace mais ne l'utilise pas ; un fichier proto V1 (`proto/framework.proto`) déclare le même paquet que le contrat qui fait autorité ; plusieurs scripts et notes isolés traînent à la racine.

3. Décisions d'architecture

Chaque décision est consignée sous forme d'ADR (Architecture Decision Record) : contexte, décision, conséquences. Une décision n'est jamais effacée : si elle est remplacée, elle passe au statut « Remplacée par ADR-xxx ».

ADR	Titre	Statut	Date
ADR-001	Haute disponibilité PME : etcd + Patroni piloté par l'orchestrateur Go	Acceptée	2026-10-28
ADR-002	Formats d'exécutables acceptés : Docker d'abord, binaires et .exe ensuite	Acceptée	2026-10-28
ADR-003	Zero-knowledge strict : aucun clair hors du cluster PME, clés confinées	Acceptée	2026-10-28
ADR-004	Modalités de la HA PME : témoin etcd, synchrone strict dès 3 nœuds, garde de quorum en lecture	Acceptée	2026-10-28
ADR-005	Installation de la pile HA chez la PME : amorçage etcd, témoin, images, secrets, HAProxy	Acceptée	2026-10-28
ADR-006	Réglages de bascule : taille du cluster retenue, `loop_wait`, cibles de délai	Acceptée (décidée seule, méthode du 29/10)	2026-10-29
ADR-007	Hébergement de l'application externe : lancement, interface, base, injection des identifiants	Acceptée (décidée seule)	2026-10-29
ADR-008	Confinement et chiffrement : réseau sans sortie, enrôlement, sauvegardes, chiffrement au repos, mesh reporté	Acceptée (décidée seule)	2026-10-29
ADR-009	Catalogue des applications hébergées : modèle, cycle de vie, rattachement à la licence	Acceptée (décidée seule)	2026-10-29
ADR-010	Récupération de la DEK après perte totale : passphrase et parts papier, vsss-rs, garde-fou, protection des anciennes sauvegardes	Acceptée (décisions 1 à 3 de l'utilisateur)	2026-11-04
ADR-011	Jeton du relais propre à chaque tenant et sauvegardes liées à leur nom	Acceptée (correctif proposé le 29/10, mis en œuvre sur demande)	2026-11-05

ADR-001 — Haute disponibilité PME : etcd + Patroni piloté par l'orchestrateur Go

Contexte. Deux mécanismes de HA coexistent (constat 1). La garde de quorum Rust (`quorum.rs`) réalise une élection de primaire écrite à la main, ce que la règle n° 2 interdit. L'orchestrateur Go, lui, s'appuie sur etcd (Raft) et Patroni, est déjà couvert par les tests d'intégration et par les mesures de bascule de la CI (switchover ~2,2 s, failover ~3,2 s).

Décision. La pile PME adopte **etcd + Patroni, piloté par l'orchestrateur Go**. C'est le seul mécanisme de bascule et de fencing en production.

Conséquences.

- Les compose PME (`pme-deploy/`, `templates/tenants/docker-compose.yml.tmpl`) intègrent etcd, Patroni (spilo) et l'orchestrateur Go, à l'image du compose de développement.
- Le nœud Rust ne promeut plus PostgreSQL lui-même (`run_supervision_loop`, sonde des pairs, `cmd/failover.rs`, `promote_standby` retirés). `quorum.rs` n'est pas supprimé mais **réorienté** en garde de quorum en lecture (voir ADR-004).
- La règle « ≥ 3 nœuds → failover automatique par quorum » est portée par etcd/Patroni. Le cas des clusters à 2 serveurs PostgreSQL est tranché par ADR-004 (témoin etcd).
- L'époque et le fencing (`epoch.rs`, `fencing.rs`) restent dans le socle ; leur source et leur contrôle continu sont fixés par ADR-004.
- **Réplication synchrone effective.** La pile V2 positionne `synchronous_commit=remote_write` sans définir `synchronous_standby_names` : PostgreSQL valide alors chaque transaction sur la seule écriture locale, la réplication est en réalité asynchrone. Cela contredit la règle « synchrone pour les invariants forts, blocage si aucun passif n'est joignable ». L'étape 2 la rend effective via Patroni (`synchronous_mode` et `synchronous_mode_strict`), qui bloque les écritures plutôt que de dégrader silencieusement en asynchrone (décision du 2026-10-28).

ADR-002 — Formats d'exécutables acceptés

Contexte. Un SaaS externe peut être livré sous plusieurs formes : image Docker, binaire Linux, exécutable Windows (.exe). Supporter tous les formats d'emblée disperserait l'effort.

Décision. AMANE accueillera **plusieurs types d'exécutables**. L'effort porte d'abord **exclusivement sur les images Docker**. Les binaires et les .exe seront développés ensuite.

Conséquences.

- Le format de description d'une application soumise (le « manifeste ») porte dès le départ un champ **type d'artefact** (`docker`, puis `binaire`, `exe`), afin que l'ajout ultérieur des autres formats n'oblige pas à casser le modèle de données ni le contrat.
- Les images sont référencées par **digest** (`sha256:…`) et non par tag, pour que la PME exécute exactement ce qui a été soumis.
- Piste pour la suite (non tranchée) : envelopper un binaire nu dans une image de base fournie par AMANE ; un .exe Windows demandera des conteneurs Windows ou une machine virtuelle.

ADR-003 — Zero-knowledge strict

Contexte. La promesse d'AMANE est que seule la PME voit ses données en clair. En V3 un acteur nouveau entre dans le périmètre : l'éditeur du SaaS externe, dont le code s'exécute **à l'intérieur** du cluster PME et manipule donc du clair.

Décision. Le zero-knowledge est maintenu sans compromis : **personne d'autre que la PME ne voit de clair**, et **la DEK comme toutes les clés de chiffrement restent dans le cluster PME**.

Conséquences.

- **Confinement réseau** : l'application externe s'exécute sur un réseau interne sans sortie vers Internet par défaut. Seuls sont exposés son interface utilisateur (via le reverse proxy du nœud) et sa base de données gérée par AMANE. Elle ne peut pas renvoyer de données en clair à son éditeur.
- **Chiffrement au repos** : les données de l'application (base, volumes) sont chiffrées sous des clés dérivées de la hiérarchie AMANE ; la DEK ne quitte jamais le cluster.
- **Sortie uniquement chiffrée** : sauvegardes, réplication inter-sites et tout transit par le relais sont chiffrés côté PME avant envoi. Le relais ne voit que des blobs opaques.
- **Télémétrie** : le SaaS éditeur AMANE ne reçoit que des métadonnées (état du cluster, licence, santé), jamais de contenu métier.
- **Aucun composant hors PME** (Django, relais, éditeur externe, agent IA) ne touche AK/DEK. Les opérations sur les clés restent humaines.

ADR-004 — Modalités de la haute disponibilité PME

Contexte. ADR-001 confie la HA à etcd + Patroni + orchestrateur Go. Sept points restaient à trancher pour la pile PME réelle, répartie sur plusieurs machines. Le plus structurant : etcd n'opère qu'avec une majorité de ses membres ; avec deux membres, la perte de **l'une ou l'autre** machine arrête etcd, et Patroni repasse alors le primaire en lecture seule par sécurité. Une question de fond a aussi été posée : retirer l'élection du nœud Rust fait-il perdre la garantie de quorum ?

Décisions (2026-10-28).

#	Sujet	Décision
1	Clusters à 2 serveurs PostgreSQL	**Témoin etcd sur une 3e machine de la PME** : etcd seul, sans PostgreSQL ni données. La majorité etcd survit à la perte d'une machine ; la bascule automatique devient possible ; tout reste chez la PME
2	Réplication synchrone	**Stricte à partir de 3 serveurs PostgreSQL** (écritures bloquées si aucun standby synchrone) ; **en dessous, non stricte avec alerte visible** dans la console : le cluster continue d'écrire quand son standby tombe, mais la PME est prévenue qu'elle n'est plus protégée
3	Version PostgreSQL	**17** (image Spilo), une seule version à maintenir
4	Clusters déjà installés	**Réinstallation des bancs** (Pilote AMANE, AMANE Test) ; pas de migration de données
5	Accès au primaire	**HAProxy local** sur chaque machine, qui interroge Patroni (`GET /primary`) : adresse fixe pour le nœud et pour l'application externe
6	Chiffrement du trafic entre machines	**Reporté à l'étape 4** (mesh WireGuard, `orchestrator-go/mesh`) ; ce trafic reste dans le périmètre PME. *Reporté de nouveau au-delà de l'étape 7 : voir ADR-008, décision 5*
7	Source de l'époque	**Timeline PostgreSQL** : incrémentée à chaque promotion, persistée, identique sur tous les nœuds, ne recule jamais

Le quorum reste une garantie du socle. Ce qui sort du nœud Rust, c'est la **décision** de promouvoir (désormais prise par Raft via etcd, et appliquée par Patroni). Ce qui reste dans le socle et dans l'image du nœud, c'est la **vérification** et l'**application** :

- `quorum.rs` est réorienté en **garde de quorum en lecture** : une fonction pure classe l'état lu dans etcd/Patroni en « sain », « sous le seuil » ou « quorum perdu ». Elle reste testable unitairement ; elle ne promeut plus rien.

- `epoch.rs` et `fencing.rs` sont conservés ; l'époque est la timeline PostgreSQL.
- Le nœud contrôle son époque **en continu** (et non plus au seul démarrage) : époque dépassée → plus d'écriture dans `ss-journal`, plus d'annonce comme primaire ; cluster sous le seuil → signalement au portail.

Limites de l'existant que cette décision corrige. L'élection de `quorum.rs` reposait sur les sondes de chaque nœud (des partitions asymétriques donnent des vues divergentes), ne persistait aucune décision, tirait l'époque d'un compteur local vérifié au seul démarrage, et ne rétrogradait jamais un primaire isolé.

Preuves attendues. Chaque promesse est vérifiée par un scénario de chaos automatisé sur un laboratoire simulant trois machines (sous-étape 2a) : arrêt brutal du primaire, primaire isolé (doit cesser d'écrire), partition minoritaire (aucune promotion), cluster 2 + témoin, perte d'un standby en mode strict et non strict.

ADR-005 — Installation de la pile HA chez la PME

Contexte. La sous-étape 2b remplace la pile PME V2 (PostgreSQL nu, bascule décidée par le nœud Rust) par la pile validée en laboratoire (ADR-004). Il faut décider comment elle s'installe sur des machines réelles. En préparant ce travail, un défaut de zero-knowledge a été relevé : les mots de passe PostgreSQL et pgAdmin d'une PME sont dérivés de son jeton d'enregistrement (`_derive_credentials`), que le portail de l'éditeur connaît ; l'éditeur peut donc les recalculer, et l'espace PME du portail les affiche. C'est contraire à ADR-003.

Décisions (2026-10-28).

#	Sujet	Décision
1	Formation du cluster etcd	Un **conteneur d'initialisation** exécuté une fois au démarrage, écrit en Go dans l'image de l'orchestrateur : il demande au portail les IP des machines déjà installées, se fait ajouter au cluster etcd **directement sur le réseau local** (`member add`) et écrit la configuration d'etcd. Logique testable, identique sous Windows et Linux ; installeurs allégés
2	Installation d'un témoin	Un **installeur « témoin » distinct**, téléchargeable depuis l'espace PME ; le portail le propose quand le cluster compte 2 serveurs
3	Provenance des images	Toutes servies par le **registre de l'éditeur** et **épinglées par digest** (`sha256:…`) : la PME exécute exactement ce qui a été validé
4	Mots de passe de la base	**Générés aléatoirement sur la première machine** et transmis aux suivantes par etcd, donc uniquement sur le réseau de la PME. L'éditeur ne peut plus les connaître ; le portail cesse d'afficher les identifiants pgAdmin, visibles uniquement en local
5	Configuration de HAProxy	**Régénérée et rechargée par l'orchestrateur** à partir des membres Patroni enregistrés dans etcd

Conséquences.

- Le portail ne fournit que des métadonnées (IP des machines) ; l'amorçage etcd, les secrets et le routage vers le primaire se font sur le réseau de la PME.
- Sécurité de l'amorçage : une machine qui connaît des pairs mais ne parvient à en joindre aucun **refuse de créer un cluster séparé** (sinon deux clusters indépendants, donc deux primaires). Créer un nouveau cluster malgré des pairs connus exige une action explicite.
- Tant que le nœud Rust n'est pas recentré (2c), sa bascule automatique est neutralisée par configuration (`CLUSTER_PEERS` vide) : deux décideurs simultanés provoqueraient un double primaire.

- Les secrets transitent en clair entre machines de la PME jusqu'au mesh WireGuard (étape 4, ADR-004 décision 6) ; ils ne sortent jamais du réseau de la PME.

ADR-006 — Réglages de bascule

Contexte. La sous-étape 2d devait rendre la réplication synchrone effective selon la taille du cluster (ADR-004, décision 2) et trancher les délais de bascule laissés ouverts en 2a. Décision prise seule, selon la méthode convenue le 29/10 : option recommandée retenue, options écartées consignées.

Décisions.

#	Sujet	Décision	Options écartées
1	Taille du cluster pour le mode strict	Le **maximum de serveurs observés**, mémorisé dans etcd (`/amane/config/serveurs_installes`). Seul l'orchestrateur élu (lease etcd) applique `synchronous_mode_strict` par l'API Patroni	Le nombre de serveurs vivants : la panne d'un serveur dans un cluster de 3 aurait retiré la protection au moment où elle compte le plus
2	`loop_wait` de Patroni	**Conservé à 2 s**	1 s : mesuré en laboratoire (10/10 scénarios), gain ≤ 1 s sur la bascule et ~1,3 s sur la mise hors service d'un primaire isolé (qui n'acquitte de toute façon aucune écriture), pour une charge d'écriture etcd doublée
3	Cibles de délai	**< 5 s** pour un crash de processus, **≈ 5 s** pour la perte d'une machine, **< 8 s** pour une partition. La partition est volontairement plus lente : la garde anti-partition attend l'expiration du heartbeat avant de forcer	Abaisser le heartbeat ou les confirmations : risque de bascule forcée sur une simple coupure réseau

Conséquences. Retirer définitivement un serveur du cluster suppose d'abaisser la valeur mémorisée (`etcdctl put /amane/config/serveurs_installes <n>`) ; c'est une opération d'administration humaine, documentée ici.

ADR-007 — Hébergement de l'application externe

Contexte. L'étape 3 fait du nœud l'hôte d'exécution d'un SaaS externe livré en image Docker (ADR-002), sans modifier son interface ni sa couche métier. Décisions prises seules (méthode du 29/10).

#	Sujet	Décision	Options écartées
1	Lancement	**Service déclaratif** `amane-application` dans la pile générée, image épinglée par digest ; Docker redémarre le conteneur	Le nœud pilotant Docker par son socket : équivaut à lui donner les droits root de la machine
2	Interface utilisateur	Le nœud **relaie** l'application à la racine de son port web (reverse proxy, réponses en flux) ; sa propre console passe sous `/amane/`	Publier directement le port de l'application : contournerait le nœud et tout contrôle futur (appairage d'appareil, ADR-003)
3	Base de données	L'orchestrateur crée un rôle `application` et sa base (dont il est propriétaire), mot de passe généré et partagé par etcd ; l'application rejoint sa base par HAProxy (toujours le primaire)	Base partagée avec le nœud ; rôle superutilisateur

#	Sujet	Décision	Options écartées
4	Injection des identifiants	Un **lanceur statique** (le binaire de l'orchestrateur, copié dans un volume par l'amorçage) est le point d'entrée du conteneur : il lit les identifiants, compose les variables décrites par le manifeste (`DATABASE_URL`…), puis exécute la commande d'origine de l'image. Aucune image n'est modifiée ; aucun mot de passe n'apparaît dans la configuration du conteneur	Variables dans le compose (le portail connaîtrait le mot de passe) ; `env_file` (lu par Compose avant que les secrets n'existent) ; reconstruire l'image de l'éditeur
5	Manifeste	JSON validé par le portail (`tenants/manifeste.py`) : type d'artefact, image par digest, commande d'origine, port, chemin de santé, variables, modèles de variables de base, volumes. `binaire` et `exe` sont refusés pour l'instant (ADR-002)	Déduire tout de l'image (commande, port) : fragile et opaque

Conséquences. L'application doit savoir lire sa base depuis une variable d'environnement (cas usuel des SaaS). Les WebSockets ne sont pas encore relayés. La sécurité du relais (contrôle d'appareil appairé devant l'interface) reste ouverte (ADR-003).

ADR-008 — Confinement et chiffrement

Contexte. L'étape 4 met en œuvre ADR-003 : le code de l'éditeur tourne dans le cluster et manipule du clair. Il ne doit rien pouvoir envoyer dehors, la DEK doit atteindre chaque serveur sans circuler en clair, et tout ce qui sort (sauvegardes) doit être chiffré côté PME. Décisions prises seules (méthode du 29/10).

#	Sujet	Décision	Options écartées
1	Confinement réseau	L'application est seule sur un réseau Docker **interne** (`internal: true`, aucune route vers l'extérieur). Seuls le nœud (qui relaie son interface) et HAProxy (qui mène à sa base) y sont attachés ; etcd, PostgreSQL, l'orchestrateur et pgAdmin n'y sont pas	Pare-feu `iptables` ou proxy sortant filtrant (exige `NET_ADMIN`, inopérant sous Docker Desktop) ; réseau `none` (l'application ne joindrait plus sa base)
2	Enrôlement des serveurs suivants	**Opération humaine des deux côtés.** Un administrateur génère, dans la console d'un serveur qui détient la DEK (`/amane/admin/enrolement`), un code à usage unique (16 caractères, 15 minutes, tous les codes annulés après 5 échecs). Sur le nouveau serveur, il lance `ss-node enroler --depuis … --code …`. La DEK lui est renvoyée **scellée pour sa clé publique** (`DevicePublicKey::seal_dek`, `ss-crypto`) ; il vérifie qu'elle s'ouvre avant de l'enregistrer	DEK partagée par etcd (en clair sur le réseau PME, lisible par le témoin) ; parts Shamir à chaque ajout (lourd pour une PME) ; transmission automatique à tout nouveau membre (contraire à la règle « les opérations sur les clés restent humaines »)

#	Sujet	Décision	Options écartées
3	Sauvegardes	Le **primaire autorisé à écrire** exporte chaque base (`pg_dump`, format custom), chiffre l'export avec la DEK et le dépose sur le relais en blob opaque. Première sauvegarde 5 minutes après la prise de rôle, puis toutes les 24 h ; rotation sur 7 jours par la clé du blob (`sauvegarde-<base>-<jour>`) ; chaque dépôt est consigné dans le journal du nœud. `ss-node sauvegarder` force une sauvegarde ; `ss-node restaurer --base … --jour …` restaure (opération humaine)	pgBackRest ou WAL-G vers un stockage objet (chiffrement par mot de passe hors de la hiérarchie AMANE, dépendance à un cloud) ; sauvegarde orchestrée par le portail (il verrait du clair)
4	Chiffrement au repos	**Délégué au chiffrement du disque** de chaque machine (BitLocker sous Windows, LUKS sous Linux). L'installeur le vérifie, avertit s'il est absent et l'état remonte au portail (`Device.chiffrement_disque`), qui pourra le signaler à la PME. Non bloquant	Volume chiffré (gocryptfs, LUKS en fichier) sous clé dérivée de la DEK : FUSE ou privilèges impossibles sous Docker Desktop, et le déverrouillage à chaque redémarrage exigerait une opération humaine sur la clé ; TDE : absent de PostgreSQL
5	Chiffrement entre machines (mesh WireGuard)	**Reporté au-delà de l'étape 7** (modifie ADR-004, décision 6). Ce trafic reste sur le réseau local de la PME ; la DEK n'y circule jamais en clair (décision 2) et les sauvegardes sortent chiffrées (décision 3)	Mesh dès maintenant : exige `NET_ADMIN` et le module noyau WireGuard dans les conteneurs, non garanti sous Docker Desktop (WSL2) ; à valider sur le banc d'abord
6	Taille des blobs du relais	Limite portée à 1 Gio par blob (2 Mo par défaut dans axum)	Découpage en morceaux : prématuré pour la taille des bases d'une PME

Conséquences. Une application qui appellerait une API externe (licence, télémétrie, paiement) ne fonctionnera pas : c'est voulu, et la question de la licence de l'application reste ouverte (§ 7). Un serveur ajouté sans enrôlement fonctionne (réplication, bascule), mais ne peut ni chiffrer son journal ni sauvegarder ; s'il devient primaire, il le signale dans ses journaux. La promesse « chiffré au repos » dépend de la PME : AMANE la vérifie et la signale, sans pouvoir l'imposer.

ADR-009 — Catalogue des applications hébergées

Contexte. L'étape 5 donne au SaaS éditeur AMANE de quoi admettre un SaaS externe et l'attribuer à des PME ; jusqu'ici `application_du_tenant` ne renvoyait rien. Décisions prises seules (méthode du 29/10).

#	Sujet	Décision	Options écartées
1	Où vit l'application	Application Django dédiée `applications`, modèle `Application` (nom, éditeur, version, manifeste normalisé, statut) : un **catalogue** indépendant des PME, une même application pouvant être hébergée par plusieurs	Manifeste stocké sur la licence ou le tenant (dupliqué pour chaque PME, aucune vue d'ensemble pour l'éditeur)
2	Rattachement	`License.application` (clé étrangère facultative, `PROTECT`) ; la pile reprend l'application de la **licence active la plus récente**, comme le reste de l'espace PME	Lien direct tenant ↔ applications (plusieurs) : la pile n'héberge qu'un service `amane-application` (applications multi-conteneurs : point ouvert)

#	Sujet	Décision	Options écartées
3	Cycle de vie	`brouillon` → `validee` → `retiree`. La **validation** vérifie le manifeste et la présence de l'image, par son digest, dans le registre de l'éditeur (`HEAD /v2/…/manifests/<digest>`) : une PME ne reçoit jamais une pile qu'elle ne pourrait pas tirer. Seule une application validée se rattache ; une application retirée disparaît des piles générées ensuite	Validation déclarative sans vérification du registre (erreur découverte chez la PME) ; suppression pure (perte de traçabilité)
4	Immuabilité	Le manifeste est **figé** dès la validation : changer d'image, c'est une nouvelle version (`nom` + `version` uniques), rattachée explicitement. Une application rattachée ne se supprime pas (`409`), elle se retire	Manifeste modifiable : une PME exécuterait, à la prochaine génération, un code différent de celui qui a été validé
5	Ce que voit la PME	Nom, éditeur, version, statut de son application (`GET /api/tenants/me/`), jamais le manifeste	Exposer le manifeste (détails d'exécution sans utilité pour la PME)

Conséquences. Le portail ne stocke que des manifestes (aucune donnée de PME, aucun secret de base : ils sont générés dans le cluster, ADR-007). La publication de l'image du SaaS externe dans le registre reste une opération de l'éditeur AMANE (comme pour la pile, `scripts/publier-pile.sh`). Une machine déjà installée ne reçoit la nouvelle version qu'en régénérant sa pile.

ADR-010 — Récupération de la DEK après perte totale

Contexte. Dans la pile Docker, la DEK n'existe que sur les serveurs enrôlés. Si tous sont perdus, les sauvegardes déposées sur le relais deviennent illisibles (constat de l'étape 7, analyse du 29/10). Le socle contenait des briques (Argon2id, KEK, Shamir 2 sur 3, scellement X25519), mais aucune n'était branchée dans la pile, et le Shamir était écrit à la main, contrairement à la règle n° 1. Décisions 1 à 3 prises par l'utilisateur le 2026-11-04 ; décisions 4 à 8 prises pour les mettre en œuvre.

#	Sujet	Décision	Options écartées
1	Mode de récupération	**Deux facteurs, tous deux exigés** : la passphrase du gérant (ce qu'il sait) et 2 parts papier sur 3 (ce qu'il détient)	Passphrase seule : une passphrase faible ou divulguée suffirait. Parts seules : deux feuilles volées suffiraient
2	Partage de Shamir	**Bibliothèque vsss-rs 6.0.1** (partage octet par octet sur GF(256), Rust pur, conçue pour éviter branchements et tables dépendant du secret, audits annoncés). Elle remplace l'arithmétique de `shamir.rs`	Dérogation écrite pour le code maison ; `blahaj` (moins utilisée, aucun audit annoncé) ; `shamirsecretsharing` (secret figé à 64 octets, parts de 113 octets à recopier)
3	Garde-fou	**Contraindre l'installation, jamais l'activité.** À sa première connexion à la console du nœud, l'administrateur est envoyé sur la page de récupération ; il la configure ou la reporte, et le report est consigné. Tant qu'elle n'est pas configurée : « installation incomplète » et alerte dans l'espace PME, pastille dans la console de l'éditeur, bandeau dans la console du nœud. L'application et les sauvegardes ne sont jamais bloquées	Alerte seule (facile à ignorer) ; blocage de l'état « prêt », de l'application ou des sauvegardes (bloque l'activité, pousse à une passphrase faible, et des sauvegardes bloquées aggravent une perte)

#	Sujet	Décision	Options écartées
4	Construction	`K_p = Argon2id(passphrase, sel)` ; `K_s` aléatoire de 32 octets, découpé en 3 parts dont 2 suffisent ; `KEK = BLAKE2b-256` à clé `K_s` sur une étiquette et `K_p` ; une paire X25519 de récupération est dérivée de la KEK ; la DEK est scellée pour sa clé publique (sealed box existante de `ss-crypto`). Tout est composé dans `ss-crypto`, sans primitive maison	La KEK emballant directement la DEK : toute republication du blob exigerait la passphrase
5	Republication	La clé publique de récupération est gardée dans la base `amane`, répliquée sur tous les serveurs. Tout serveur qui détient la DEK peut **resceller et republier** le blob sans la passphrase, par exemple si le relais l'a perdu	Blob créé une seule fois, au moment de la configuration
6	Où vit le blob	Sur le relais (clé `recuperation`), et **imprimé sur chaque feuille**. La récupération ne dépend donc pas de la disponibilité de l'éditeur	Relais seul (l'éditeur deviendrait indispensable) ; feuille seule
7	Anciennes sauvegardes	Le blob porte une **empreinte de la DEK** (BLAKE2b à clé, qui ne révèle rien de la DEK). Un primaire dont la DEK ne correspond pas à l'empreinte du blob présent sur le relais ne dépose aucune sauvegarde et le signale : c'est un cluster réinstallé après une perte totale, qui écraserait sinon les sauvegardes du jour par une base vide. `ss-node recuperer` remplace alors la DEK neuve par la DEK récupérée et met de côté le journal local, chiffré par la DEK neuve	Laisser la nouvelle installation écraser les sauvegardes ; ne rien vérifier
8	Parts papier et passphrase	Une part fait 33 octets (identifiant + 32), écrits en base32 par groupes de 4, suivis d'une somme de contrôle liée au jeu de parts : une faute de frappe ou une part d'un autre jeu est signalée dès la saisie. Passphrase d'au moins 12 caractères, saisie deux fois, jamais stockée ni transmise. Argon2id en réglage RFC 9106 (64 Mio, 3 passes, 4 voies), paramètres inscrits dans le blob pour pouvoir évoluer	Parts en hexadécimal (plus longues) ; aucune somme de contrôle (erreur découverte seulement à la reconstitution)

Conséquences. La configuration est une opération humaine, comme l'enrôlement : ni le portail ni le relais ne voient la passphrase, les parts ou la KEK. Le relais ne stocke que du chiffré et une empreinte. Reconfigurer (nouvelle passphrase, nouvelles parts) **n'invalide pas** les anciennes feuilles : leur bloc imprimé contient la même DEK, scellée sous l'ancienne clé. Elles doivent être détruites ; seule une rotation de la DEK, non prévue à ce jour, les rendrait inutilisables. Le point ouvert « Paramètres Argon2id » est clos : les valeurs du socle correspondent à la deuxième recommandation de RFC 9106.

ADR-011 — Jeton du relais propre à chaque tenant et sauvegardes liées à leur nom

Contexte. Le relais acceptait un jeton global facultatif que la pile ne transmettait pas : en pratique (banc compris), quiconque connaissait l'identifiant d'un tenant pouvait lire, écraser ou supprimer ses blobs, sauvegardes et blob de récupération compris, et écrire de fausses adresses dans sa topologie. Indépendamment, une sauvegarde déplacée sous un autre nom (autre jour, autre base) se déchiffrait sans erreur : la restauration aurait rendu silencieusement d'anciennes données. Le correctif avait été proposé le 29/10 (§ 6, « Jeton du relais et intégrité des sauvegardes ») ; l'utilisateur a demandé de passer à l'étape 9 le 2026-11-05.

#	Sujet	Décision	Options écartées
1	Forme du jeton	`HMAC-SHA256(RELAY_SECRET, "amane-relais/v1/" ‖ tenant)` en hexadécimal. Le secret est partagé entre le portail et le relais ; le portail calcule le jeton, le relais le recalcule à chaque requête et le compare en temps constant. Aucune base côté relais. Fonction dans `ss-crypto` (`hmac` et `sha2` de RustCrypto) ; côté portail, `hmac` et `hashlib` de la bibliothèque standard ; un vecteur de test commun verrouille l'accord des deux	Jeton global unique : un tenant écraserait les blobs d'un autre. Jeton aléatoire par tenant stocké par le relais : une base à tenir et à synchroniser depuis le portail. Réutiliser le jeton d'enregistrement : le relais devrait interroger le portail, et ce jeton circule dans les URL des installeurs
2	Portée	**Blobs et topologie** : `GET`, `PUT` et `DELETE` de `/api/blobs/<tenant>/…`, l'annonce (`POST /api/nodes/announce`) et la lecture (`GET /api/nodes`) exigent le jeton du tenant concerné. `/health` reste libre et indique `authentification: true` ou `false`	Blobs seuls : n'importe qui pourrait glisser de fausses adresses dans la topologie d'un tenant
3	Remise à la pile	**Valeur fixée par le portail dans la pile serveur** (`RELAY_AUTH_TOKEN` du service `ss-node`), pas dans le `.env` écrit par l'installeur : retélécharger la pile suffit à la renouveler. Le témoin, qui ne joint pas le relais, n'en reçoit pas	`.env` de l'installeur : renouveler le jeton exigerait de relancer l'installeur
4	Relais sans secret	**Refus de démarrer.** Le mode ouvert existe pour le laboratoire, mais doit être demandé (`RELAY_SANS_AUTHENTIFICATION=1`) ; un secret de moins de 32 caractères est refusé même dans ce mode. `relay-deploy/setup.sh` génère le secret (`openssl rand -hex 32`) et l'affiche pour le `.env` du portail	Relais ouvert par défaut (comportement antérieur) : c'est ainsi que le banc tournait sans protection sans que personne ne l'ait choisi
5	Liaison au nom	Chaque blob de sauvegarde commence par un **en-tête en clair** `amane-sauvegarde/1 <tenant> <base> <date>`, que le chiffrement **authentifie comme donnée associée** (XChaCha20-Poly1305, `Dek::encrypt_avec_contexte`). La restauration vérifie que le tenant, la base et le jour de la semaine de la date correspondent au nom du blob, refuse sinon, et affiche la date de la sauvegarde restaurée. Un en-tête réécrit pour correspondre au nouveau nom fait échouer le déchiffrement	Données associées sans en-tête : la restauration devrait deviner la date. Jour seul au lieu de la date : l'opérateur ne verrait pas l'âge de la sauvegarde. Second MAC séparé : une clé de plus, pour ce que l'AEAD fait déjà
6	Anciens blobs	Les blobs sans en-tête (antérieurs à l'étape 9) sont **refusés** à la restauration : aucune PME n'est en production, et la rotation sur 7 jours les remplace d'elle-même	Lecture de compatibilité : elle rouvrirait précisément le défaut corrigé

Conséquences. Le portail, donc l'éditeur AMANE, connaît les jetons : il peut lire et supprimer les blobs d'un tenant, ce que l'exploitant du relais pouvait déjà faire sur son disque. Le zero-knowledge n'en dépend pas : les blobs restent chiffrés par la DEK, que ni le portail ni le relais ne détiennent. L'en-tête révèle au relais le nom de la base et la date de la sauvegarde ; le nom du blob et l'heure du dépôt les lui donnaient déjà. Un détenteur du jeton peut encore remettre sous son nom une sauvegarde plus ancienne du même jour de la semaine (d'une semaine précédente) : elle est acceptée, mais sa date est affichée à la restauration. Renouveler le jeton d'un seul tenant exige aujourd'hui de changer le secret commun, donc de retélécharger la pile de tous les tenants (§ 7).

4. Tri du dépôt

4.1 À garder intact

Composant	Justification
`spike/crates/ss-crypto` (AK, DEK, CRL, Shamir, device_key, recovery)	Socle de la souveraineté, indépendant de tout métier
`spike/crates/ss-journal`	Journal CBOR chiffré append-only, générique
`ss-consensus/src/epoch.rs`, `fencing.rs`	Anti split-brain générique (lease etcd)
`spike/relay/`, `relay-deploy/`	Le relais zero-knowledge convient tel quel
`proto/amane/framework/v1/`, `tests/contracts/`, `buf.gen.yaml`	Contrat figé : on pourra ajouter des messages, jamais modifier l'existant
`orchestrator-go/` (consensus, supervisor, grpcserver, mesh, replication, telemetry)	Devient le moteur HA de production (ADR-001)
Modèles `Tenant`, `License`, `Device` ; `devices/api_register.py` ; `api/`	Comptes, licences et identité d'installation inchangés
`.github/workflows/`, `.ci/`, `scripts/*_measure.sh`, `docs/bench/`	Garde-fous CI et mesures de bascule

4.2 À garder mais adapter

Composant	Adaptation prévue
`spike/node`	Devient l'**hôte d'exécution** : garde init, run, status, delist, le client relais et le heartbeat SaaS ; gagne le lancement et la supervision de l'application externe à partir de son manifeste, la base PostgreSQL gérée, et un reverse proxy qui sert l'interface de l'application telle quelle
`core-rust/ss-client`	N'est plus un SDK intégré par l'application (elle reste inchangée). `license.rs`, `pairing.rs` et `offline.rs` sont rapatriés dans le nœud ou conservés comme bibliothèque interne
Django (`tenants/`, `licenses/`, `devices/`, `dashboard/`)	Nouveau modèle **Application** (image soumise, digest, manifeste : ports, volumes, base requise, variables), rattaché à la licence ; génération des installeurs et du compose incluant l'application
`templates/tenants/*.tmpl`, `pme-deploy/`	Ajout du service applicatif et de la pile etcd/Patroni/orchestrateur (ADR-001) ; `watchtower` revu (mise à jour par digest vérifié uniquement) ; `pgadmin` rendu optionnel
`frontend/`	Garde Tenants, Licences, Appareils, Clusters, Relais, MonEspace, Login, Register, Déploiement ; ajoute une page Applications ; met à jour la page Architecture
`ss-consensus/src/supervision.rs`	**Supprimé (2c)** : le nœud lit Patroni ; `ss-consensus` ne dépend plus de `sqlx`
`ss-consensus/src/quorum.rs`	**Reclassé (ADR-004)** : initialement à supprimer, il est réorienté de l'élection vers une garde de quorum en lecture (sain / sous le seuil / perdu)

Composant	Adaptation prévue
`README.md`, `CLAUDE.md`, `ACCES-INTERFACES.md`, `CONTRAT-API.md`, `Architecture_SaaS_Souverain_Trois_Acteurs.md`	Réécrits une fois la refonte stabilisée

4.3 À supprimer

Élément	Raison
`spike/node/src/stock/` et les routes HTML liées au stock	Métier AMANE remplacé par le SaaS externe
`core-rust/ss-client/src/invariants.rs`	Invariants propres au stock
`frontend/src/pages/StockPage.tsx`	Écran du métier supprimé
`proto/framework.proto`	Vestige V1, même paquet que le contrat qui fait autorité
Console Django en double : `templates/**/*.html`, `views_web.py`, `views_espace.py`, `dashboard/views*.py`, `urls.py` web, `static/`	Doublon de la console React (couverture vérifiée écran par écran). Les `.tmpl` (générateurs d'installeurs) sont conservés. **Correction** : les `views.py` de `tenants/`, `licenses/` et `devices/` sont les ViewSets DRF de l'API et restent en place
`spike/node/Dockerfile.stub`, `.gitkeep` inutiles	Vestiges
`fix_locks.py`, `verify.py`, `docker-cleanup.ps1`	Scripts ponctuels ; `fix_locks.py` contient un mot de passe en clair
`.agenthub/sessions/`	Sans rapport avec le projet
`paroles_explication_mission_b.txt`	Note personnelle
`impact_missions_v1_vers_v2 (1).md`, `Stack_Technique_Framework_Souverainete_SaaS (1).md`, `schema_soutenance.html`	Déplacés vers `docs/archive/` plutôt que supprimés (le schéma de soutenance n'a pas d'équivalent React)

5. Plan de travail par étapes

Étape	Contenu	Statut
0	Branche `main3`, instantané V2, présent document	Terminée
1	Nettoyage : suppressions du § 4.3, un commit par catégorie	Terminée
2a	Image Docker de l'orchestrateur ; laboratoire simulant trois machines ; scénarios de chaos prouvant chaque promesse (ADR-001, ADR-004)	Terminée
2b	Gabarit compose PME (etcd, Patroni, orchestrateur, HAProxy), installeurs, génération par le portail, tests Django (ADR-005)	Réalisée ; validation sur le banc AMANE Test à faire (annexe)
2c	Recentrage du nœud Rust : retrait de la promotion, garde de quorum en lecture, époque = timeline, fencing continu, séparation de `NODE_MODE`	Terminée
2d	Réplication synchrone et alerte sous le seuil, mesures de bascule sur le banc réinstallé	Terminée (mesures en laboratoire ; banc à faire)
3	Nœud → hôte d'exécution : manifeste, lancement et supervision d'une image Docker, reverse proxy de l'interface (ADR-002, ADR-007)	Terminée
4	Confinement et chiffrement : réseau interne sans sortie, enrôlement des serveurs, sauvegardes chiffrées via le relais, chiffrement du disque vérifié (ADR-003, ADR-008)	Terminée
5	SaaS éditeur : modèle Application, soumission d'image par digest, génération des installeurs (ADR-009)	Terminée
6	Console React : page Applications, mise à jour Architecture	Terminée
7	Documentation : README, CLAUDE.md, accès, contrat d'API	Terminée
8	Récupération de la DEK après perte totale : passphrase du gérant (Argon2id) et parts papier (Shamir, vsss-rs), blob sur le relais et sur papier, commande `ss-node recuperer`, garde-fou (ADR-010)	Terminée le 2026-11-04 (banc à faire)
9	Jeton du relais propre à chaque tenant, transmis par la pile ; blobs de sauvegarde liés à leur nom (tenant, base, jour) (ADR-011)	Terminée le 2026-11-05 (banc à faire)
10	Images V3 reconstruites et publiées (nœud, orchestrateur, pile) ; portail et console de l'éditeur reconstruits ; relais reconstruit et redémarré avec `RELAY_SECRET`, le même secret dans le `.env` du portail	Réalisée le 2026-10-29 (à refaire après les étapes 8 et 9)
11	Préparation de la séance de banc : IP du jour, relais, anciennes machines désactivées, application d'exemple poussée, validée et rattachée à AMANE Test	Réalisée côté éditeur le 2026-11-04 (banc sur Tailscale) ; reste l'application de l'équipe
Banc	Validation sur machines réelles (annexe) : installation, bascule, application hébergée, enrôlement, sauvegarde, récupération après perte totale	À faire

Étape	Contenu	Statut
Plus tard	Binaires Linux et .exe Windows (ADR-002)	Prévu

6. Journal des étapes

Étape 0 — Préparation (2026-10-28)

- Création de la branche `main3` depuis `main2` (`e0f6d09`) et publication sur `origin/main3`.
- Commit `6da5022` « chore: état V2 avant nettoyage » : 76 fichiers V2 jusque-là non suivis ou non commités (pages React clusters, relais, espace tenant ; API DRF clusters, relais, statistiques, images ; quorum `ss-consensus` ; documents d'accès et de déploiement).
- Inventaire du dépôt et tri initial (§ 4).
- Décisions ADR-001, ADR-002 et ADR-003 actées.
- Création du présent document et de son générateur PDF.

Étape 1 — Nettoyage (2026-10-28)

Quatre commits, un par catégorie, pour que chacun reste lisible et réversible.

Commit	Contenu
`7ca8e78`	Racine : retrait de `fix_locks.py` (mot de passe en clair), `verify.py`, `docker-cleanup.ps1`, `.agenthub/`, d'une note personnelle ; deux notes de cadrage archivées dans `docs/archive/`
`81d7081`	Vestiges : `proto/framework.proto` (V1), `spike/node/Dockerfile.stub`, `.gitkeep` inutiles, dossier `infra/` vide. `CLAUDE.md` et le serveur gRPC pointent vers le seul proto restant
`5609fb6`	Métier stock : module `spike/node/src/stock/`, `ss-client/src/invariants.rs`, `StockPage.tsx` (routée nulle part). La racine `/` du nœud affiche une page « Application hébergée », futur point d'entrée du reverse proxy (étape 3). Authentification et console cluster du nœud conservées
`dc06197`	Console Django : vues et gabarits HTML retirés ; les fonctions partagées avec l'API passent dans des modules `services.py` (historique conservé), la voie PME par jeton dans `tenants/api_pme.py`. Aucune URL d'API ne change

Choix faits pendant l'étape.

- `quorum.rs` reste en place jusqu'à l'étape 2 : le retirer avant qu'etcd/Patroni n'arrivent dans la pile PME supprimerait toute bascule automatique chez les clients.
- Les tables `articles` et `mouvements_stock` déjà créées dans les bases PME ne sont pas supprimées : le nœud ne les crée plus, mais effacer des données client n'est pas du ressort d'un nettoyage de code.
- Le schéma de soutenance, sans équivalent React, est archivé plutôt que supprimé.

Vérifications.

- Django : `manage.py check` sans erreur ; 75 tests exécutés sur SQLite en mémoire, 74 réussis. L'échec (`test_options_de_replication_postgres`) existait déjà avant le nettoyage (vérifié sur le commit `098f1de`), voir § 7.
- Frontend : `npm run build` et `npm run lint` sans erreur.
- Go : `go build ./...` sans erreur.
- Rust : **non compilé** pendant l'étape (Docker arrêté sur le poste, aucun toolchain local) ; diff relu à la main. Compilation confirmée ensuite, voir les compléments ci-dessous.

Étape 1 — Compléments (2026-10-28)

Compilation Rust (via Docker, `rust:1.88-bookworm`).

- `spike/` : compile, 74 tests réussis, 0 échec.
- `core-rust/ss-client` : compile, 7 tests unitaires réussis.
- Les avertissements restants (`delete_session` jamais appelée, champ `node_id` jamais lu, variable `e` inutilisée dans `ss-journal`) existaient avant le nettoyage ; ceux du module stock ont disparu avec lui.

Test d'intégration `core-rust/ss-client/tests/mock_server.rs` retiré. Il implémentait le contrat V1 (`RegisterNode`, `WriteOperation`, `GetClusterStatus`) alors que `build.rs` génère les bindings depuis le contrat V2 : 25 erreurs de compilation, déjà présentes avant le nettoyage (vérifié sur `098f1de`). Il empêchait `cargo test` de lancer les tests unitaires de `ss-client`. Une version alignée sur le contrat V2 pourra être écrite si le besoin revient.

Test `test_options_de_replication_postgres` corrigé. Le test attendait `max_wal_senders=3` et `wal_keep_size=64` ; le gabarit compose (comme `pme-deploy/`) utilise 5 et 512. Le second écart était masqué par l'arrêt du test au premier échec. Les valeurs du gabarit font foi :

- `max_wal_senders=5` : deux standbys en flux et un `pg_basebackup -Xs` (qui occupe deux émetteurs) doivent pouvoir coexister sur un cluster de trois nœuds ; avec 3, le reclonage d'un standby peut être refusé.
- `wal_keep_size=512` (Mo) : un standby redémarré ou brièvement coupé rattrape son retard sans être recloné ; 64 Mo n'offrent pas cette marge.

Le test est aligné et commenté. Suite Django : 75 tests, 75 réussis.

Constat reporté à l'étape 2. En analysant ce test, la réplication s'est révélée asynchrone de fait (`synchronous_commit=remote_write` sans `synchronous_standby_names`). Correction décidée pour l'étape 2, consignée dans ADR-001.

Étape 2a — Image de l'orchestrateur et laboratoire HA (2026-10-28)

Objectif. Avant de modifier la pile installée chez les PME (2b) et le nœud Rust (2c), prouver que l'architecture décidée par ADR-001 et ADR-004 tient ses promesses quand on la casse. La preuve est apportée par un laboratoire qui simule trois machines sur un seul poste, et par des scénarios de chaos automatisés qui rendent un verdict OK / ÉCHEC.

Ce qui a été livré

Fichier	Rôle
`orchestrator-go/Dockerfile`, `.dockerignore`	Image de l'orchestrateur (binaire Go statique, utilisateur non privilégié, 33 Mo). Elle n'existait pas : l'orchestrateur n'était lancé qu'à la main
`ha-lab/docker-compose.yml`	Laboratoire : trois « machines » simulées, deux topologies
`ha-lab/chaos.sh`	Les scénarios de chaos et leur bilan (topologie `temoin`, `trois-pg` ou `tout`, filtre de scénario optionnel)
`ha-lab/README.md`	Notice du laboratoire
`orchestrator-go/supervisor/beacon.go`, `supervisor.go`, `consensus/client.go`	Trois défauts corrigés (voir plus bas)

Fichier	Rôle
`orchestrator-go/supervisor/beacon_integration_test.go`	Test de non-régression du défaut de heartbeat
`.ci/testcontainers/main.go`, `.github/workflows/build-go.yml`, `chaos-tests.yml`	etcd de CI réglé comme en production ; nouveau test ajouté à la campagne de chaos CI

Le laboratoire

Chaque « machine » `mN` est un groupe de conteneurs relié à deux réseaux : `lan`, qui joue le réseau local de la PME, et `mN`, qui joue le bus interne de la machine. Débrancher les conteneurs d'une machine du réseau `lan` simule un câble réseau arraché : ils continuent de se voir entre eux, mais plus les autres machines. Sur `lan`, chaque conteneur a une IP fixe et les services se désignent par IP, comme de vraies machines.

Machine	etcd	PostgreSQL + Patroni	Orchestrateur
m1	10.77.0.11	10.77.0.12	10.77.0.13
m2	10.77.0.21	10.77.0.22	10.77.0.23
m3	10.77.0.31	10.77.0.32 (topologie trois-pg)	10.77.0.33 (topologie trois-pg)

Deux topologies, qui correspondent aux deux cas d'ADR-004 :

- **Topologie « témoin »** : deux serveurs PostgreSQL (m1, m2) et un témoin etcd seul sur m3 (décision 1). Réplication synchrone **non stricte** (décision 2).
- **Topologie « trois-pg »** : trois serveurs PostgreSQL. Réplication synchrone **stricte**.

Réglages Patroni communs : `ttl` 20 s, `loop_wait` 2 s, `retry_timeout` 5 s, `synchronous_mode` activé. Chaque topologie est recréée à neuf avant ses scénarios.

Comment les pannes sont simulées

Panne réelle	Simulation dans le laboratoire
PostgreSQL ou Patroni plante, la machine reste en vie	`docker kill -s KILL` du seul conteneur PostgreSQL ; l'etcd et l'orchestrateur de la machine continuent de tourner
La machine s'éteint brutalement (coupure de courant)	`docker kill -s KILL` de tous les conteneurs de la machine
Câble réseau arraché, switch défaillant	Débranchement de tous les conteneurs de la machine du réseau `lan` ; ils restent vivants

Comment le verdict est rendu

- **Écriture acquittée** : un `INSERT` est acquitté si PostgreSQL confirme le `COMMIT` en moins de 5 s. En réplication synchrone, ce `COMMIT` n'est confirmé qu'après réception par le standby synchrone : une écriture acquittée existe donc sur deux machines.
- **Leader** : il est lu dans etcd **auprès de la majorité**. Un membre etcd isolé refuse de répondre (lecture linéarisable), on interroge alors le suivant.
- **Rétrogradation** : on vérifie que PostgreSQL n'accepte plus d'écriture (`pg_is_in_recovery()` vrai, ou PostgreSQL arrêté). Le rôle annoncé par l'API REST de Patroni ne suffit pas : un primaire privé d'etcd peut encore renvoyer son dernier rôle connu alors que Patroni a déjà arrêté PostgreSQL.

- **Zéro perte** : un marqueur est écrit et acquitté juste avant la panne ; il doit se retrouver sur le nouveau primaire.
- **Retour à la normale** : après chaque scénario, le cluster doit se reformer complètement (tous les membres présents, un leader, au moins un standby synchrone).

Les scénarios et les promesses qu'ils prouvent

1. Crash du PostgreSQL primaire. On tue le seul processus PostgreSQL du primaire. On vérifie qu'un autre nœud devient primaire et acquitte des écritures, que le marqueur est présent (zéro perte), puis qu'au redémarrage l'ancien primaire revient **en réplica** et non en second primaire. *Promesse : bascule automatique sans perte, et fencing de l'ancien primaire.*

2. Panne de la machine du primaire. On tue toute la machine du primaire : son etcd, son PostgreSQL, son orchestrateur. On vérifie la bascule et le zéro perte. Dans la topologie témoin, c'est le témoin etcd qui fournit la majorité : sans lui, etcd s'arrêterait et Patroni bloquerait toute écriture. *Promesse : la majorité restante suffit à basculer (décision 1 d'ADR-004).*

3. Isolement réseau du primaire. C'est le scénario le plus exigeant : le primaire est coupé du réseau mais reste vivant. Pendant qu'une écriture est tentée sur ce primaire isolé, on surveille la bascule côté majorité. On vérifie que **le primaire isolé n'acquitte aucune écriture**, que la majorité élit un nouveau primaire, que l'ancien cesse lui-même d'accepter des écritures, et qu'au retour du réseau **l'écriture non acquittée n'apparaît nulle part** dans le cluster (elle est effacée par `pg_rewind`). *Promesse : jamais deux primaires capables d'acquitter une écriture (anti split-brain).*

4. Perte du standby, non strict (topologie témoin). On tue la machine du standby. On vérifie que les écritures reprennent rapidement sur le primaire, désormais sans standby synchrone. *Promesse : en dessous de 3 serveurs PostgreSQL, le cluster continue d'écrire (décision 2) ; l'alerte « vous n'êtes plus protégé » est à ajouter à l'étape 2d.*

5. Isolement du témoin etcd (topologie témoin). On coupe le témoin du réseau pendant 15 s. On vérifie que le primaire ne change pas et que les écritures continuent. *Promesse : le témoin ne crée pas de point de défaillance.*

6. Partition minoritaire d'un standby (topologie trois-pg). On isole un standby pendant 30 s. On vérifie qu'il ne se promeut jamais, que le primaire reste le même et qu'il continue d'acquitter des écritures grâce à l'autre standby. *Promesse : un nœud minoritaire ne peut jamais devenir primaire.*

7. Blocage strict sans standby (topologie trois-pg). On tue les deux standbys. On vérifie que le primaire **n'acquitte plus aucune écriture**, puis que les écritures reprennent au retour des standbys. *Promesse : en mode strict, aucune écriture n'est confirmée si elle n'existe pas sur deux machines (décision 2).*

Les scénarios 1 à 3 sont joués sur les deux topologies : 10 exécutions au total.

Résultats (campagne finale)

Scénario	Témoin (2 PG + témoin)	Trois-pg (3 PG, strict)
1. Crash du PostgreSQL primaire	OK — bascule en 3,7 s, zéro perte	OK — bascule en 3,3 s, zéro perte
2. Panne de la machine du primaire	OK — bascule en 5,7 s, zéro perte	OK — bascule en 4,8 s, zéro perte
3. Isolement réseau du primaire	OK — aucune écriture acquittée par l'isolé ; bascule en 6,3 s ; l'isolé n'accepte plus d'écriture après 9,5 s ; écriture non acquittée écartée	OK — mêmes vérifications ; bascule en 7,3 s ; isolé hors service après 9,8 s

Scénario	Témoin (2 PG + témoin)	Trois-pg (3 PG, strict)
4. Perte du standby, non strict	OK — écritures reprises en 1,2 s	—
5. Isolement du témoin	OK — aucun effet pendant 15 s	—
6. Partition minoritaire	—	OK — aucune promotion en 30 s
7. Blocage strict	—	OK — aucune écriture acquittée sans standby, reprise au retour

Toutes les promesses de sécurité sont tenues : zéro perte, aucun double primaire, aucune promotion minoritaire, blocage strict effectif.

Défauts trouvés et corrigés dans l'orchestrateur

Les premières campagnes ont mis au jour trois défauts réels du superviseur Go, invisibles dans les tests existants qui ne simulaient pas de partition réseau entre machines.

Défaut	Effet constaté	Correction
Client etcd sans keepalive gRPC	Après une partition, le client restait accroché à sa connexion vers le membre etcd isolé : heartbeats, droit de forcer et libération du verrou échouaient tous. La bascule n'était plus accélérée et retombait sur le `ttl` de Patroni (21 à 26 s)	Keepalive d'une seconde (`consensus/client.go`). Le serveur etcd doit l'accepter : `--grpc-keepalive-min-time 1s` (laboratoire, CI, et pile PME à l'étape 2b)
Délai de libération du verrou Patroni trop court	La suppression du verrou dans etcd avait 300 ms (le délai d'une sonde REST) ; juste après une partition, elle échouait et toute la détection repartait de zéro	Délai d'écriture etcd dédié de 2 s (`supervisor.go`)
Heartbeat jamais rétabli après une isolation (défaut de sécurité)	Une fois reconnecté, l'orchestrateur réutilisait une lease etcd expirée et ne battait plus jamais le cœur de son nœud. Si ce nœud redevenait primaire, la garde anti-partition ne le protégeait plus : une simple coupure REST aurait pu déclencher une bascule forcée à tort	Session recréée dès que la lease est morte (`beacon.go`). Test d'intégration `TestHeartbeatSessionRecreatedAfterLeaseLoss` : **il échoue sur le code d'origine et passe avec la correction**

Effet mesuré des corrections sur l'isolement du primaire : de 21,8 à 25,8 s avant, à 6,3 et 7,3 s après.

Artefacts de laboratoire corrigés

Ces écarts tenaient au laboratoire ou au script de test, pas à l'architecture ; ils sont consignés parce que certains renseignent l'étape 2b.

- **Adresse annoncée par Spilo.** Spilo ignore `PATRONI_POSTGRESQL_CONNECT_ADDRESS` et lit `PG_CONNECT_ADDRESS` / `RESTAPI_CONNECT_ADDRESS`, avec pour défaut l'IP du conteneur. Après une reconnexion réseau, l'adresse annoncée était périmée. *Pour 2b : annoncer l'IP LAN de la machine.* Le compose de développement est concerné.
- **DNS d'un conteneur arrêté.** La résolution du nom d'un conteneur arrêté met environ 3 s à échouer, ce qui retardait la promotion. D'où les IP fixes, plus fidèles à une PME.
- **Rôle REST en cache.** Voir « Rétrogradation » ci-dessus.

- **Rythme des scénarios.** Voir le cooldown ci-dessous.
- **Mesure de l'isolement.** La tentative d'écriture sur le primaire isolé est menée en parallèle de la surveillance de la bascule ; menée avant, elle ajoutait 5 s à la mesure.

Comportements à connaître

- **Cooldown de 30 s.** Après une bascule forcée, l'orchestrateur s'interdit d'en forcer une autre pendant 30 s (anti-oscillation). Une seconde panne dans cette fenêtre n'est rattrapée que par le `ttl` de Patroni (environ 20 s).
- **Rétrogradation hors ligne.** Un primaire privé d'etcd est **arrêté** par Patroni (« demoting self, offline ») et reste arrêté tant que le réseau n'est pas revenu ; il rejoint ensuite le cluster en réplica.
- **Passage en asynchrone (non strict).** Quand le standby d'un cluster à 2 serveurs tombe, Patroni retire le standby synchrone et les écritures reprennent en asynchrone. C'est le comportement voulu par la décision 2 ; l'alerte reste à construire (2d).
- **Option `synchronous_mode_stop_on_limit`.** Vérifié dans le code de Patroni 4.0.4 (image Spilo) : cette option n'existe pas et est ignorée. Seules `synchronous_mode` et `synchronous_mode_strict` existent. Le compose de développement est à corriger.

Délais de bascule et cible de 5 s

Les crashs de processus basculent en 3,3 à 3,7 s et la panne d'une machine en 4,8 à 5,7 s, autour de la cible. L'isolement réseau prend 6,3 à 7,3 s. Ce délai a une borne basse structurelle : avant de forcer, l'orchestrateur doit constater que le heartbeat du primaire a expiré (lease de 2 s, puis 2 confirmations à 0,5 s d'intervalle). Ce délai est justement ce qui empêche de forcer une bascule sur une simple coupure REST. Ensuite, Patroni ne traite la demande qu'à son tour de boucle suivant (`loop_wait` 2 s). Deux leviers sont à évaluer à l'étape 2d, sur le banc réel : `loop_wait` à 1 s, et la durée du heartbeat. Les deux augmentent le risque de fausse détection ; la cible sera tranchée sur mesures réelles.

Vérifications

- Go : `go build`, `go vet`, tests unitaires de tous les paquets réussis.
- Intégration sur etcd réel (harnais CI) : `consensus`, `supervisor` et `mesh` réussis, dont le nouveau test de non-régression ; ce dernier échoue sur le code d'origine.
- Chaos : 10 scénarios sur 10 réussis sur la campagne finale.
- Aucun changement Django, React ni Rust dans cette sous-étape.

Étape 2b — Pile PME réelle (2026-10-29)

Objectif. Faire de la pile validée en laboratoire (2a) ce que le portail génère et ce que les installeurs déploient réellement chez une PME, selon les cinq décisions d'ADR-005.

Comment une PME s'installe désormais

1. **Premier serveur.** L'installeur écrit un `.env` (IP LAN, nom de la machine), télécharge la pile et la démarre. L'amorçage (`orchestrator init`) demande au portail les machines déjà installées : il n'y en a pas, il crée un cluster etcd à un membre. L'orchestrateur génère les mots de passe, les enregistre dans etcd, crée le rôle `amane` sur le primaire et écrit la configuration HAProxy.

2 **Serveur suivant.** Le portail lui donne l'IP du premier. L'amorçage s'ajoute au cluster etcd **directement sur le réseau local** (`member add`), l'orchestrateur lit les mêmes mots de passe dans etcd, Patroni clone la base et en fait un standby synchrone.

3 **Témoin.** Même amorçage, puis etcd seul ; il s'annonce au portail (type `temoin`) et ne consomme pas de poste.

Plus aucune question n'est posée à l'installation (fini « IP du nœud primaire ? ») et aucun mot de passe n'est calculé par l'installeur ni connu du portail.

Ce qui a été livré

Domaine	Fichiers	Contenu
Orchestrateur Go	`bootstrap/`, `cmd/orchestrator/pme.go`	Sous-commande `init` : amorçage etcd (création, ajout, refus de créer un cluster séparé si des machines connues sont injoignables), droits des volumes, secrets générés et partagés par etcd
	`dcs/`, `haproxy/`	Lecture des membres et du leader Patroni ; configuration HAProxy régénérée et rechargée à chaud
	`provision/`	Rôle `amane` et base `amane` créés sur le primaire (idempotent)
	`portail/`, sous-commande `temoin`	Liste des machines, signalement du témoin (métadonnées seules)
	`supervisor/`, `consensus/client.go`	Découverte des membres dans etcd ; client etcd qui apprend tous les membres à partir de l'etcd local
Pile générée	`templates/tenants/docker-compose.yml.tmpl`, `docker-compose-temoin.yml.tmpl`	Serveur : amorçage, etcd, Spilo/Patroni 17, orchestrateur, HAProxy, nœud, pgAdmin ; témoin : amorçage, etcd, signalement
Installeurs	`install-linux.sh.tmpl`, `install-windows.bat.tmpl`	8 étapes identiques ; type de machine ; arrêt de l'ancienne pile V2 sans perte de ses volumes ; nouveau dossier d'installation
Portail	`tenants/pile.py`, `tenants/services.py`, `api_espace.py`, `api_pme.py`	Images épinglées par digest (503 sans manifeste) ; paramètre `?type=` (serveur ou témoin) ; suppression des mots de passe dérivés ; témoin conseillé
	`devices/` (migration 0006)	`node_kind` ; un témoin ne consomme pas de poste
Console	`MonEspacePage.tsx`, types, client	Plus de mot de passe affiché ; encart et installeurs du témoin
Publication	`scripts/publier-pile.sh`	Pousse les six images dans le registre de l'éditeur et écrit leurs digests
Essais	`ha-lab/pme/`	Laboratoire d'installation machine par machine
Divers	`docker-compose.yml` (dev), `CONTRAT-API.md`, CI	Variables Spilo corrigées, option inexistante retirée ; contrat d'API à jour ; nouveaux paquets au plancher de couverture

Choix faits pendant la sous-étape

- **Rôle de connexion `amane` créé par l'orchestrateur.** Spilo ne fournit qu'un rôle `admin` sans droit de connexion (son `post_init` force `NOLOGIN`, et Patroni 4 a retiré `bootstrap.users`). L'orchestrateur, qui détient le mot de passe superutilisateur sans qu'il quitte la PME, crée le rôle et la base de façon idempotente. C'est aussi la brique dont l'étape 3 aura besoin pour la base de l'application hébergée.
- **Connexions non chiffrées admises sur le réseau PME** (`ALLOW_NOSSL`). Spilo refuse par défaut toute connexion distante sans TLS ; le nœud (sqlx sans TLS) et bien des applications ne savent pas chiffrer. Le chiffrement entre machines viendra du mesh WireGuard (étape 4, ADR-004 décision 6).
- **Le nœud reste connecté à son PostgreSQL local** (et non à HAProxy) jusqu'à son recentrage (2c) : il continue ainsi de lire le vrai rôle de sa machine. Sa bascule est neutralisée (`CLUSTER_PEERS` vide).
- `NODE_MODE` **change de sens** : il ne désigne plus le rôle PostgreSQL mais le premier serveur, qui génère la DEK. Détecté par l'installeur via `cluster-status` (les témoins ne comptent pas).
- **Watchtower retiré.** Avec des images épinglées par digest, une mise à jour passe par une nouvelle publication et une nouvelle pile, jamais par un remplacement automatique.
- **Repli sur l'archive de l'image retiré.** Une image chargée depuis une archive n'a pas le digest du registre : elle contredirait l'épinglage.
- **Réinstallation des bancs** (ADR-004 décision 4) : nouveau dossier (`/opt/amane-pme`, `%PROGRAMDATA%\Amane\PME`) ; l'ancienne pile est arrêtée mais ses volumes sont conservés.

Défauts trouvés et corrigés en cours de route

Défaut	Comment il a été trouvé	Correction
Spilo ignore `PGPASSWORD_REPLICATION` et les `PATRONI_*_PASSWORD` : le mot de passe de réplication restait `standby`	Lecture du code de Spilo	Variables lues par Spilo (`PGPASSWORD_STANDBY`…) ; compose de développement corrigé
Rôle `admin` de Spilo sans connexion	Laboratoire d'installation	Rôle `amane` créé par l'orchestrateur
Client figé derrière HAProxy après la panne d'une machine (connexion vers une machine morte jamais coupée après un rechargement)	Laboratoire d'installation	`hard-stop-after 30s`, `retries`, `option redispatch`
Digest d'une image multi-architecture absent du registre (« manifest unknown » chez la PME)	Essai sur trois machines	Le script de publication lit le digest auprès du registre
Membres Patroni nommés d'après l'identifiant du conteneur : l'orchestrateur ne reconnaissait pas son nœud	Essai sur trois machines	`hostname` du conteneur PostgreSQL = nom de la machine ; test Django dédié
Identifiant du témoin non inscriptible (volume root, orchestrateur non privilégié)	Relecture	Dossier préparé par l'amorçage
Vulnérabilité de `pgx` v5.7.5 (GO-2026-5004) et de `x/text` v0.37 rendue atteignable	`govulncheck`	`pgx` v5.9.2, `x/text` v0.41.0

Vérifications

- **Go** : build, vet, tests unitaires et d'intégration sur etcd réel, tous réussis. Couverture par paquet : `dcs` 93 %, `portail` 85 %, `bootstrap` 74 %, `haproxy` 67 %, `provision` 42 % (son test d'intégration exige un PostgreSQL, absent en CI ; paquet hors plancher).

- **Django** : 71 tests réussis, dont une suite V3 de la pile (`tenants/tests.py`) : images épinglées et refus sans manifeste, absence de secret, bascule du nœud neutralisée, nom du membre Patroni, témoin, parité des installeurs, `.bat` en ASCII pur.
- **Frontend** : build et lint sans erreur.
- **Laboratoire d'installation** (`ha-lab/pme`) : 4 vérifications sur 4 (premier serveur, ajout du second avec les mêmes secrets, témoin, bascule vue par HAProxy en 6,5 s sans perte).
- **Essai Docker-dans-Docker** : trois « machines » à IP, moteur Docker et ports publiés propres, faisant tourner **le compose généré par le portail** et les images publiées par le script : premier serveur leader, second en standby synchrone, mêmes secrets, témoin à 3 membres etcd, puis coupure brutale de la machine du primaire → écritures reprises par le HAProxy de l'autre machine en 7 s, zéro perte.
- **À faire** : validation sur le banc AMANE Test (procédure en annexe) — pare-feu Windows, Docker Desktop, vraies IP LAN.

Commits.

Commit	Contenu
`2722c6a`	Orchestrateur : amorçage etcd, secrets partagés, rôle `amane`, HAProxy, témoin, découverte des membres ; laboratoire `ha-lab/pme` ; CI
`08fa0a3`	Portail : gabarits serveur et témoin, images épinglées, suppression des secrets côté portail, installeurs, `node_kind`, console, script de publication, tests V3, compose de développement, contrat d'API

Suite. La sous-étape 2c (recentrage du nœud Rust) n'est pas lancée : elle attend la validation de 2b sur le banc AMANE Test et l'accord explicite pour démarrer.

Méthode de travail à partir du 2026-10-29

À la demande de l'utilisateur, les étapes restantes (2c à 7) sont enchaînées sans validation intermédiaire. Après chaque étape : mise à jour de ce journal, **un commit local, aucun push**. Tout point à trancher est décidé selon l'option recommandée et consigné ici sous forme d'ADR, avec les options écartées.

Étape 2c — Recentrage du nœud Rust (2026-10-29)

Objectif. Appliquer ADR-004 au nœud : il ne décide plus d'aucune bascule, il **vérifie** et **fait respecter** l'état décidé par etcd et appliqué par Patroni.

Ce qui a changé.

Élément	Avant	Après
Décision de bascule	`run_supervision_loop` : sonde des pairs (`CLUSTER_PEERS`), élection par LSN (`decider_failover`), `pg_promote`	Supprimée. Bascule manuelle : `patronictl switchover`
`ss-consensus/src/quorum.rs`	Élection écrite à la main	Garde de quorum en lecture : `evaluer_quorum` classe l'état Patroni en `sain`, `sous_le_seuil`, `perdu` (fonction pure, 7 tests)
`ss-consensus/src/supervision.rs`	Lecture de PostgreSQL et promotion	Supprimé ; `ss-consensus` ne dépend plus de `sqlx`
Époque	Compteur dans `config.toml`, vérifié au démarrage	Timeline PostgreSQL publiée par Patroni (`epoque_cluster`), vérifiée **à chaque tick** (5 s)

Élément	Avant	Après
Rôle annoncé au portail	`pg_is_in_recovery()` ou `NODE_MODE`	Rôle Patroni de la machine (`spike/node/src/patroni.rs`), et seulement s'il n'est pas fencé
`ss-node failover`	Promotion manuelle par `pg_promote`	Commande retirée
`NODE_MODE`	Rôle PostgreSQL **et** génération de la DEK	Uniquement « premier serveur » : génère la DEK au premier démarrage
Connexion PostgreSQL du nœud	PostgreSQL local	HAProxy (toujours le primaire) ; migrations idempotentes jouées par chaque nœud
Page « Cluster » de la console du nœud	Vues `pg_stat_*` locales	État Patroni : membres, rôles, époque, état du quorum

Fencing continu. À chaque tick, une fonction pure (`decider`, 4 tests) fixe le droit d'écrire : le nœud n'écrit dans son journal en tant que primaire que si Patroni le dit primaire, que le quorum n'est pas perdu et que sa timeline est la plus récente du cluster. Un ancien primaire revenu avec une timeline inférieure est fencé, même si son PostgreSQL se croit encore primaire ; il s'annonce alors `standby`. La prise de rôle primaire est consignée dans `ss-journal` avec l'époque.

DEK. En mode Docker, chaque serveur générait sa propre DEK (le code le signalait comme provisoire) : les données chiffrées n'auraient pas été lisibles d'une machine à l'autre. Désormais seul le premier serveur la génère ; les suivants démarrent sans DEK, « en attente d'enrôlement », sans redémarrer en boucle (le nœud fonctionne, son journal est désactivé). L'enrôlement des serveurs suivants est traité à l'étape 4.

Remontée au portail. Le nœud transmet désormais l'état du cluster (`etat_quorum`) à chaque battement de cœur ; son stockage et l'alerte associée relèvent de 2d.

Vérifications. Workspace `spike/` : compilation et tests réussis (16 tests du nœud, 19 de `ss-consensus`, 21 de `ss-crypto`, 6 de `ss-journal`) ; `core-rust/` : 7 tests réussis ; Django : test de la pile adapté (le nœud lit Patroni et écrit par HAProxy ; plus de `CLUSTER_PEERS`). L'essai de bout en bout du nœud recentré est joué à la fin de 2d, avec l'alerte.

Étape 2d — Réplication synchrone, alerte et mesures (2026-10-29)

Ce qui a été fait.

- **Mode synchrone selon la taille du cluster** (`orchestrator-go/synchrone/`, option `-synchrone-auto`) : strict à partir de 3 serveurs, non strict en dessous, appliqué par l'orchestrateur élu via `PATCH /config` de Patroni (ADR-006, décision 1). Couverture 73 %, test d'intégration sur etcd réel.
- **Alerte « sous le seuil »** : le nœud remonte l'état du cluster (`etat_quorum`) à chaque battement de cœur et **immédiatement** à chaque changement (au lieu d'attendre jusqu'à 60 s). Le portail l'enregistre (`Device.etat_quorum`, migration 0007), en déduit l'état du tenant (pire état parmi ses serveurs en ligne, `Tenant.etat_cluster`) et alerte :

- **espace PME** : bandeau « Vos données ne sont plus protégées » ou « Votre cluster ne peut plus écrire » ; - **console éditeur** (supervision des clusters) : nouveaux motifs `quorum_lost`, `unprotected`, `no_witness`.

- **Mesures** : campagne de chaos rejouée avec `loop_wait` à 1 s ; résultat et décision dans ADR-006.

Vérifications.

- Django : 74 tests réussis (dont 3 nouveaux sur l'état du cluster) ; frontend : build et lint sans erreur ; Go : tests unitaires et d'intégration réussis.
- **Essai sur trois machines** (Docker-dans-Docker, pile générée, images publiées, nœud recentré de 2c) : 13 vérifications sur 13 — premier serveur leader et DEK générée, second en standby synchrone et « en attente d'enrôlement », témoin, nœud voyant le cluster sain, mode non strict à deux serveurs, état « sain » au portail ; puis coupure brutale de la machine du primaire → bascule et écriture par HAProxy en 10 s sans perte, **alerte « sous le seuil » au portail en 1 s** ; retour de l'ancienne machine en standby (20 s) et état redevenu « sain ».
- Journaux du nœud pendant l'essai : « sous le seuil » → « sain » → « quorum perdu » (pendant la bascule) → « sous le seuil » (époque 3) → « sain » ; prise de rôle primaire consignée dans `ss-journal` avec l'époque.

Reste à faire sur le banc AMANE Test : mêmes vérifications sur machines réelles (annexe), en particulier les délais de bascule sous Docker Desktop.

Étape 3 — Le nœud, hôte d'exécution (2026-10-29)

Ce qui a été fait (ADR-007).

Domaine	Fichiers	Contenu
Manifeste	`tenants/manifeste.py`	Schéma, validation (14 cas de refus testés), mise en forme pour la pile (valeurs YAML sûres, `$` échappé pour Compose)
Pile générée	`docker-compose.yml.tmpl`	Service `amane-application` conditionnel : image par digest, lanceur en point d'entrée, commande d'origine, variables, volumes ; rien ne change pour un tenant sans application
Orchestrateur	`lanceur/` (couverture 100 %), `cmd/orchestrator/lancer.go`, `provision/`, `bootstrap/`	Sous-commande `lancer` (attend les identifiants, rend les modèles, remplace son processus par la commande d'origine) ; copie du binaire statique par l'amorçage ; rôle et base `application` créés sur le primaire ; noms SQL validés et échappés
Nœud	`spike/node/src/application.rs`, `web.rs`, `auth/routes.rs`, `cmd/run.rs`	Reverse proxy (en-têtes de connexion filtrés, `X-Forwarded-*`, redirections laissées au navigateur, réponses en flux) ; console du nœud sous `/amane` ; sonde de santé toutes les 30 s ; état remonté au portail
Portail	`devices` (migration 0008)	`Device.etat_application` (`ok` / `ko`)
Exemple	`ha-lab/application-exemple/`	SaaS d'exemple qui ne connaît que `DATABASE_URL`, image `FROM scratch` (ni shell ni outils)

Le rattachement d'une application à la licence d'un tenant relève de l'étape 5 : jusque-là, `application_du_tenant` ne renvoie rien.

Vérifications.

- Django : 82 tests réussis, dont 8 sur le manifeste et la pile avec application (service, lanceur, aucun mot de passe dans la pile, nœud configuré, témoin sans application, application sans base).
- Go : `lanceur` 100 %, tests de la sous-commande `lancer` et de la copie du binaire ; suite complète sur etcd réel réussie. Un échec isolé du superviseur est survenu une fois sous la forte charge de l'essai en parallèle (test d'intégration sensible au temps), non reproduit sur deux exécutions suivantes.

- Rust : 20 tests du nœud, dont un relais de bout en bout vers une vraie application HTTP (méthode, chemin, requête, corps, cookies, en-têtes de connexion filtrés) et l'application absente (502).
- **Essai sur trois machines — interrompu.** Claude Code a arrêté l'essai faute de mémoire sur le poste ; il n'a pas été relancé, conformément à la consigne. Ce qu'il avait validé sur la première machine : l'application d'exemple **démarre dans son image** `scratch` (le lanceur injecte `DATABASE_URL`, l'orchestrateur a créé le rôle et la base, l'application les joint par HAProxy), et la sonde du nœud la voit passer d'« indisponible » à « disponible ». Restent à jouer, quand la mémoire le permettra : page servie par le proxy des deux machines, compteur partagé, continuité après bascule (script d'essai conservé hors dépôt, à réintégrer à `ha-lab`).

Étape 4 — Confinement et chiffrement (2026-10-29)

Ce qui a été fait (ADR-008).

Domaine	Fichiers	Contenu
Confinement	`docker-compose.yml.tmpl`	Réseau `amane-application` interne, créé seulement si le tenant héberge une application ; l'application n'est que sur lui ; nœud et HAProxy y sont attachés
Enrôlement	`spike/node/src/enrolement.rs`, `cmd/enroler.rs`, `auth/routes.rs`, `web.rs`	Codes à usage unique (alphabet sans caractères ambigus, saisie tolérante), page d'administration « Enrôlement », route `POST /amane/api/enrolement` authentifiée par le seul code, commande `ss-node enroler`
Sauvegardes	`spike/node/src/sauvegarde.rs`, `cmd/sauvegarder.rs`, `cmd/run.rs`, `node/Dockerfile`	Export, chiffrement par la DEK, dépôt et restauration ; planification dans la boucle de supervision (seulement quand l'écriture est autorisée) ; client PostgreSQL 17 dans l'image du nœud (dépôt officiel PGDG, même version que Spilo)
Relais	`spike/relay/src/main.rs`	Routes de blobs corrigées et limite de taille (voir plus bas) ; premiers tests du relais
Chiffrement du disque	installeurs Linux et Windows, `devices` (migration 0009), `api_register.py`	Détection LUKS (`lsblk`) et BitLocker (`Get-BitLockerVolume`), avertissement en fin d'installation, `Device.chiffrement_disque` (`oui`, `non` ou `inconnu`)

Défauts trouvés et corrigés.

- **Les routes de blobs du relais n'ont jamais fonctionné.** Elles étaient écrites `/api/blobs/{tenant_id}/{key}`, syntaxe d'axum 0.8, alors que le relais utilise axum 0.7, où les paramètres s'écrivent `:nom` : la route était prise au pied de la lettre et tout dépôt répondait 404. Corrigé et couvert par un test de bout en bout (dépôt de 3 Mo, relecture, suppression).
- `ss-node adduser` ignorait `PG_URL` et ne pouvait pas joindre la base dans la pile (il ne lisait que le fichier de configuration).

Vérifications.

- Django : 100 tests réussis (+18), dont le réseau interne (application isolée, seuls nœud et HAProxy attachés, aucun réseau applicatif sans application), la détection du chiffrement dans les deux installeurs et son enregistrement par le portail (valeur invalide refusée).

- Rust : workspace `spike` complet réussi ; nœud 28 tests (+8 : codes à usage unique, annulation après échecs, DEK scellée ouverte par le seul destinataire, clés de rotation, lecture des secrets, blob illisible sans la DEK), relais 2 tests (dépôt de bout en bout, refus des évasions de chemin).
- **Essais légers sur Docker réel** (deux ou trois conteneurs, scripts hors dépôt) :

- sauvegarde, 6/6 : export chiffré déposé ; aucune donnée en clair dans le blob du relais (ni les données, ni l'en-tête `PGDMP`) ; table supprimée puis restaurée depuis le relais ; une autre DEK ne peut pas restaurer ; - enrôlement, 7/7 : code émis par la console du serveur A ; B démarre sans DEK ; un faux code est refusé ; B enrôlé avec le vrai code ; pas de second enrôlement ; la DEK de B est scellée pour sa propre clé ; - confinement : depuis un réseau interne, aucune sortie vers Internet, le voisin du réseau reste joignable.

Étape 5 — Catalogue des applications du SaaS éditeur (2026-10-29)

Ce qui a été fait (ADR-009).

Domaine	Fichiers	Contenu
Modèle	`applications/models.py`, migrations `applications/0001`, `licenses/0002`	`Application` (unicité nom + version, manifeste normalisé), `License.application`
Registre	`applications/registre.py`	Présence d'une image par son digest dans le registre (mêmes adresses que la page « Image du nœud ») ; registre injoignable distingué d'une image absente
API éditeur	`applications/views.py`, `serializers.py`, `urls_api.py`	`/api/applications/` réservé au staff : CRUD, actions `valider` et `retirer`, suppression refusée si rattachée, manifeste figé après validation
Licences	`licenses/serializers.py`	Champ `application` (seule une application validée se rattache) et `application_nom`
Pile et espace PME	`tenants/services.py`, `api_espace.py`	`application_hebergee` et `application_du_tenant` lisent la licence active ; `GET /api/tenants/me/` expose l'application (résumé)
Contrat d'API	`CONTRAT-API.md`	Section 2.8 ; champs V3 manquants ajoutés (`etat_cluster`, `etat_quorum`, `etat_application`, `chiffrement_disque`, `application`)

Vérifications. Django : 116 tests réussis (+16) : création et normalisation, manifeste invalide et format `exe` refusés, unicité, accès refusé à la PME et à l'anonyme (et `/api/applications/` ajouté aux routes éditeur verrouillées), validation selon le registre (absente, injoignable, présente, une seule fois), manifeste figé, rattachement limité aux applications validées, espace PME, retrait, suppression protégée, licence inactive, requêtes au registre (méthode, URL, 404, injoignable), et la pile générée **sans simulation** depuis le catalogue (application rattachée présente, absente du témoin, disparue après retrait). `makemigrations --check` : aucune migration manquante.

Étape 6 — Console React (2026-10-29)

Ce qui a été fait. Aucune décision d'architecture nouvelle : la console expose ce que les étapes 2d à 5 ont produit.

Domaine	Fichiers	Contenu
Applications (éditeur)	`pages/ApplicationsPage.tsx`, `App.tsx`, `Layout.tsx`	Page « Applications » : catalogue, création d'un brouillon (manifeste JSON vérifié avant envoi, erreurs du serveur affichées sur le champ), validation contre le registre, retrait avec rappel du nombre de PME concernées, suppression ; manifeste en lecture seule une fois validé
Licences	`pages/LicensesPage.tsx`	Colonne « Application » et choix de l'application hébergée (applications validées seulement)
États des machines	`components/EtatsNoeud.tsx`, `DevicesPage.tsx`, `MonEspacePage.tsx`	Pastilles « Témoin », « Application disponible / indisponible », « Disque chiffré / non chiffré »
Espace PME	`pages/MonEspacePage.tsx`	Encart de l'application hébergée (nom, version, éditeur, sans accès à Internet) ; alerte nominative sur les disques non chiffrés
Architecture	`pages/ArchitecturePage.tsx`	Contenu réécrit pour la V3 : enveloppe d'exécution, application confinée, pile etcd + Patroni + HAProxy, enrôlement par code, sauvegardes chiffrées sur le relais, règles de bascule d'ADR-004 et ADR-006, garantie zero-knowledge étendue à l'éditeur du SaaS hébergé. L'ancienne page décrivait une bascule propre au nœud, un enrôlement par QR et un stockage S3 qui n'existent pas
Types et client	`types/index.ts`, `api/client.ts`	`Application`, `ApplicationResume`, champs V3 de `Device`, `License` et `EspacePme` ; fonctions de `/api/applications/`

Vérifications. `tsc -b` sans erreur, `eslint` sans avertissement, `vite build` réussi. Les pages n'ont pas été parcourues dans un navigateur contre un portail réel (à faire lors de la validation sur le banc).

Étape 7 — Documentation (2026-10-29)

Ce qui a été fait.

Document	Changement
`README.md`	Réécrit : il décrivait la V2 (missions A, B, C) et renvoyait à un fichier absent. Il présente l'enveloppe d'exécution, les acteurs, la pile d'une machine PME, les garanties, la carte du dépôt, la publication, l'installation et les tests
`CLAUDE.md`	Carte du dépôt (applications, pile générée, laboratoire), application hébergée, clés et enrôlement, HA avec témoin, commandes (laboratoire, publication), pièges (`pme-deploy` et pages HTML retirés, syntaxe des routes axum 0.7)
`ACCES-INTERFACES.md`	Réécrit : ports de la pile PME, page Applications, routes publiques des machines, console du nœud sous `/amane/`, commandes d'enrôlement, de sauvegarde et de restauration, nouvelles pannes courantes. Les pages HTML Django et l'interface de stock, retirées, n'y figurent plus
`Architecture_SaaS_Souverain_Trois_Acteurs.md`	Réécrit pour la V3 : quatre acteurs (l'éditeur du SaaS hébergé en plus), hébergement de l'application, HA avec témoin, clés, parcours d'installation avec enrôlement, récupération ; les règles V1 remplacées sont signalées comme telles

Document	Changement
`AGENTS_IA_EXPLOITATION.md`	Assistant d'installation : topologie avec témoin ; l'enrôlement n'est plus généré par l'agent (QR) mais expliqué, l'administrateur gardant seul le code et la DEK
`CONTRAT-API.md`	Déjà mis à jour à l'étape 5
`pme-deploy/`	**Retiré.** C'était la pile V2 posée à la main (primaire et standby sans DCS, comptes de l'ancienne interface de stock), remplacée par la pile générée depuis l'étape 2b. L'historique Git et la branche `main2` la conservent

Défaut trouvé en vérifiant la documentation. L'ancienne documentation et la page Architecture de l'étape 6 annonçaient une récupération d'urgence de la DEK (code Argon2id, parts Shamir). Le socle la fournit, mais **la pile Docker ne l'utilise pas** : seule l'initialisation interactive, hors pile, crée un blob de récupération, et il reste sur la machine. Conséquence : si tous les serveurs enrôlés sont perdus, les sauvegardes du relais sont irrécupérables. La documentation et la page ont été corrigées pour dire ce qui existe, et le point est inscrit en tête du § 7. Corrigé au passage : le nœud conseillait `ss-node enroll`, la commande s'appelle `enroler`.

Vérifications. Console : `tsc -b`, `eslint`, `vite build` réussis après la correction de la page Architecture ; nœud : tests Rust réussis après la correction du message ; aucune référence restante à `pme-deploy/` dans les fichiers suivis, hors historique de ce journal.

Bilan des étapes 1 à 7

AMANE V3 sait, de bout en bout dans le code : admettre l'application d'un éditeur tiers (catalogue, validation contre le registre), l'attribuer à une PME (licence), générer sa pile et ses installeurs, l'installer en haute disponibilité (etcd + Patroni + HAProxy, témoin), exécuter l'application inchangée sur un réseau sans sortie avec sa base dédiée, transmettre la DEK aux serveurs par une opération humaine, sauvegarder chiffré sur le relais et signaler à la PME ce qui menace ses données (quorum, réplication, témoin, disque). Ce qui reste avant une mise en service est au § 7, en tête : la récupération de la DEK après perte totale, la validation sur le banc réel et l'essai de bout en bout de l'étape 3.

Séance du 2026-10-29 (après-midi) — publication et analyse de ce qui reste

Publication. Les commits des étapes 2c à 7 (`ef10bd9` à `5bfa1db`) ont été poussés sur `origin/main3` à la demande explicite de l'utilisateur ; le dépôt distant pointait jusque-là sur `cee04fd` (étape 2b).

Le parcours V3 de bout en bout

Rappel destiné aux collaborateurs, établi à partir du code de `main3`.

Moment	Ce qui se passe
Démarrer le portail	`docker compose up -d --build backend frontend` (le conteneur ne monte pas le code : toute évolution exige une reconstruction ; les migrations s'appliquent au démarrage), `docker start ss-relay`, puis `spike\build-node.ps1` et `scripts/publier-pile.sh` pour que les PME puissent télécharger la pile (sinon 503)
Admettre une application	AMANE ne construit rien : l'éditeur tiers fournit une **image déjà construite**, poussée dans le registre de l'éditeur AMANE (`:5000`), et un **manifeste JSON** (image par digest, commande d'origine, port, chemin de santé, variables, modèle de `DATABASE_URL`, volumes). Page **Applications** : brouillon, validation contre le registre (409 si l'image est absente), manifeste figé ; rattachement à la licence depuis la page **Licences**

Moment	Ce qui se passe
Arrivée d'une PME	Inscription (`/register` : compte, tenant, licence d'essai) ou création par l'éditeur ; installeurs serveur et témoin téléchargés depuis `/bienvenue` ; chaque machine s'annonce avec le jeton du tenant et son `installation_id` ; seuls les serveurs consomment des postes
Enrôlement	Le premier serveur génère la DEK ; chaque serveur suivant la reçoit scellée pour sa clé X25519, par un code à usage unique émis dans `/amane/admin/enrolement` et saisi avec `ss-node enroler`
Authentifications	Éditeur : compte Django *staff*, session et CSRF, console `:5173` (comptes partagés avec `/admin/`). Responsable PME sur le portail : compte Django rattaché au tenant (`/mon-espace`). Administrateurs PME sur leurs machines : comptes locaux du nœud (Argon2, rôles `admin` et `employee`, mot de passe `admin` affiché une seule fois au premier démarrage). Utilisateurs métier : le login propre à l'application hébergée, qu'AMANE relaie sans s'en mêler
Licences du banc	Conservées : la V3 n'a ajouté qu'un champ facultatif `application`. Les machines, elles, se réinstallent (ADR-004, décision 4) après désactivation des anciennes dans la console

Récupération de la DEK : l'existant

Le socle `ss-crypto` contient les briques prévues pour la récupération d'urgence (Mission A) :

Brique	Fichier	Rôle
Argon2id	`recovery.rs`	Dérive 32 octets d'une passphrase et d'un sel (64 Mio, 3 passes, 4 voies) ; paramètres signalés comme « non durcis pour la production »
KEK	`shamir.rs`	Clé d'enveloppe qui emballe et déballe la DEK (`wrap_dek`, `unwrap_dek`)
Shamir	`shamir.rs`	Découpe de la KEK en 3 parts dont 2 suffisent (`split_kek`, `reconstruct_kek`) ; schéma figé à 2 sur 3
X25519	`device_key.rs`	Scellement de la DEK pour la clé publique d'une machine (utilisé par l'enrôlement)

Ce que la pile en fait. Rien. L'initialisation interactive (`ss-node init --first` hors Docker) dérive bien une clé Argon2id d'un code saisi et emballe la DEK, mais le blob reste dans le `config.toml` de la machine et disparaît avec elle. Dans la pile Docker, la branche automatique d'`init.rs` génère la DEK sans aucune saisie : ni passphrase, ni blob de récupération. `split_kek` et `reconstruct_kek` ne sont appelés que par leurs tests. Il n'existe ni format papier, ni commande de reconstitution, ni combinaison passphrase + parts.

Conformité. `shamir.rs` implémente à la main l'arithmétique sur GF(256), ce que la règle n° 1 du dépôt interdit (aucune primitive cryptographique maison). Son commentaire annonce un temps d'exécution constant, ce qui est inexact : `gf_mul` comporte des branchements qui dépendent des octets secrets. Le risque pratique est faible (calcul ponctuel, sur une machine de la PME), mais le code doit être remplacé par une bibliothèque reconnue ou faire l'objet d'une dérogation écrite.

Récupération de la DEK : la proposition (étape 8)

Deux facteurs, conformément à l'intention d'origine : **ce que le gérant sait** (sa passphrase) et **ce qu'il détient** (des parts sur papier).

- À la création du cluster, une page d'administration du premier serveur (`/amane/admin/recuperation`) fait saisir la passphrase du gérant : `K_p = Argon2id(passphrase, sel)`.
- Une clé aléatoire `K_s` est découpée en parts Shamir (2 sur 3), imprimées chacune sur une feuille avec une somme de contrôle de saisie.

- La KEK est dérivée de `K_p` et `K_s` ; elle emballe la DEK. Le blob (sel compris) est déposé sur le relais, qui n'y voit que du chiffré, et imprimé avec les parts.
- Après une perte totale, `ss-node recuperer` sur une installation neuve demande la passphrase et deux parts, reconstitue la DEK et rend les sauvegardes du relais lisibles.
- Variante X25519 : dériver de la passphrase une paire de clés de récupération et sceller la DEK pour sa clé publique, ce qui permet de recréer le blob sans la passphrase lors d'un changement de DEK. Utile seulement si la rotation de la DEK est prévue.

Décisions attendues avant de coder (elles feront l'ADR-010) :

#	Sujet	Recommandation
1	Mode de récupération	Passphrase **et** parts papier (plutôt que l'un ou l'autre seul)
2	Garde-fou	Alerte bloquante au portail tant que la récupération n'est pas configurée ; à trancher : refuser aussi l'état « prêt » ou le démarrage des sauvegardes
3	Implémentation de Shamir	Remplacer le code maison par une bibliothèque reconnue, ou consigner une dérogation

Jeton du relais et intégrité des sauvegardes (étape 9)

Le relais accepte un jeton facultatif (`RELAY_AUTH_TOKEN`, en-tête `x-relay-token`) et le nœud sait l'envoyer, mais la pile générée ne le lui transmet pas. Deux cas, tous deux insatisfaisants : un relais qui exige le jeton refuse toutes les sauvegardes ; un relais qui ne l'exige pas (le banc actuel) laisse quiconque connaît l'identifiant d'un tenant lire, écraser ou supprimer ses blobs. La lecture ne livre que du chiffré (le zero-knowledge tient), mais la suppression détruit les sauvegardes. Un jeton unique pour tout le relais ne suffit pas : un tenant pourrait écraser les blobs d'un autre.

Défaut trouvé pendant l'analyse. Le chiffrement d'une sauvegarde (`sauvegarde.rs`, `Dek::encrypt`) ne lie pas le blob à son nom. Un blob déplacé, l'export du lundi à la place de celui du jeudi ou la base `amane` à la place de `application`, se déchiffre sans erreur : la restauration rendrait silencieusement d'anciennes données.

Correctif proposé. Un jeton propre à chaque tenant, créé par le portail et injecté dans le `.env` de la pile ; le relais le vérifie sans base de données (HMAC de l'identifiant du tenant sous un secret partagé entre portail et relais, implémentation RustCrypto). Les données authentifiées du chiffrement portent le tenant, la base et le jour, et la restauration refuse un blob déplacé.

Ce que la validation sur le banc doit établir

Le laboratoire simule trois machines par des conteneurs sur un seul poste ; rien de la V3 n'a tourné sur les postes du banc. Seuls ceux-ci peuvent montrer : le comportement du pare-feu Windows et du réseau de Docker Desktop, les IP réelles attribuées par DHCP, les délais de bascule sous Docker Desktop face aux cibles d'ADR-006, une coupure d'alimentation réelle suivie du retour en `Replica` puis `Sync Standby`, la détection de BitLocker et de LUKS sur de vrais disques, et la console React parcourue dans un navigateur.

L'essai de l'étape 3, interrompu faute de mémoire, n'avait validé que la première machine : application `FROM scratch` démarrée, `DATABASE_URL` injectée, rôle et base créés, base jointe par HAProxy, sonde passée à « disponible ». Restent : la page servie par le proxy des deux serveurs, un compteur écrit par un serveur et relu par l'autre (même primaire), la continuité de l'application après bascule, l'enrôlement et une sauvegarde dans le même essai, et le parcours réel du catalogue (image poussée, validée, rattachée, pile téléchargée), dont la vérification du registre n'a été testée côté Django qu'avec des réponses simulées.

Cet essai se fera sur le banc plutôt que sur le poste de développement.

Reconstruction des images (étape 10)

La console servie sur `:5173` était encore la V2 : les conteneurs du portail avaient été relancés sur des images construites deux semaines (backend) et huit semaines (frontend) plus tôt, le conteneur ne montant pas le code. Les images de la pile publiées pour l'essai de la veille l'avaient été sur un registre de laboratoire (`localhost:5055`), et non sur celui du portail ; `media/node-images/pile.json` n'existait pas, si bien que le téléchargement de la pile aurait répondu 503.

Composant	Ce qui a été fait	Vérification
Portail (backend, frontend)	`docker compose build backend frontend` puis redémarrage	Migrations V3 appliquées (`applications 0001`, `devices 0006` à `0009`, `licenses 0002`), aucune en attente ; la console servie contient la page Applications et les pastilles Témoin et Disque chiffré. Un premier démarrage a échoué sur une transaction en lecture seule, Patroni n'ayant pas encore élu de primaire ; le redémarrage automatique prévu par le compose l'a résolu
Nœud	`spike\build-node.ps1 -Version v3`	Binaire vérifié, `localhost:5000/ss-node:v3` poussé, archive hors ligne `ss-node-v3.tar.gz` (50 Mo)
Pile	`scripts/publier-pile.sh localhost:5000` (construit aussi l'orchestrateur)	`pile.json` liste six images par digest ; la pile serveur générée pour AMANE Test les référence
Relais	Image reconstruite (`ss-relay:dev`, `localhost:5000/ss-relay:dev`), conteneur recréé à l'identique (port 8080, volume `relay_blobs` conservé)	L'ancienne image datait du 15 octobre, avant la correction des routes de blobs ; `/health`, dépôt, relecture et suppression d'un blob répondent 200. Le dépôt sans jeton est accepté, ce qui confirme le constat de l'étape 9

Digests publiés le 2026-10-29 : nœud `a98b2497…`, orchestrateur `824bea25…`, PostgreSQL `17bf371c…`, etcd `9344cfb9…`, HAProxy `43f51ba5…`, pgAdmin `2fbd14f8…`. Le champ `registre` de `pile.json` vaut `localhost:5000` à titre indicatif : le portail préfixe les images par l'hôte qui a servi à joindre l'éditeur, donc l'IP du poste éditeur vue depuis la PME.

Le `Dockerfile` du nœud n'a pas de couche de cache des dépendances : une modification du code recompile tout l'espace de travail (337 crates). Une couche de cache (cargo-chef ou montage de cache) raccourcirait les reconstructions des étapes 8 et 9.

Étapes avant les tests

1. Trancher les trois décisions de la récupération de la DEK et rédiger l'ADR-010.
2. Étape 8 : récupération de la DEK (page de configuration, feuille à imprimer, blob sur le relais, `ss-node recuperer`, tests dont une perte totale simulée en laboratoire).
3. Étape 9 : jeton du relais par tenant et liaison des blobs à leur nom.
4. Étape 10 : reconstruire et republier les images (nœud, orchestrateur, pile) et le portail ; à refaire après les étapes 8 et 9.
5. Étape 11 : préparer la séance (IP du jour dans `RELAY_URL`, relais démarré, anciennes machines d'AMANE Test désactivées, application d'exemple poussée, validée et rattachée).
6. Dérouler l'annexe sur le banc, étapes 1 à 16.

Séance du 2026-11-04 — préparation de l'essai d'une application hébergée

Objectif. Être prêt à soumettre à AMANE l'application d'un éditeur tiers et à obtenir les installeurs qui enrôlent les machines d'une PME. L'application visée est une gestion de stock et de facturation, développée par d'autres membres du groupe ; en l'attendant, toute la chaîne est vérifiée avec l'application d'exemple.

Décisions de l'utilisateur.

Sujet	Décision
Soumission d'un SaaS	**Démarche actuelle conservée** (ADR-009) : l'éditeur tiers construit son image à partir de son Dockerfile, la pousse dans le registre de l'éditeur AMANE et la déclare avec son manifeste. AMANE ne construit rien. Écartés : un script de soumission (build, push et déclaration en une commande) et un envoi du Dockerfile par la console, qui ferait compiler du code tiers par le portail
Réseau du banc	**Tailscale** : le portail, le registre et le relais sont joints par `100.65.0.5`

Défaut corrigé : l'adresse annoncée par l'installeur Linux. L'installeur retenait l'adresse de la machine qui partage les trois premiers octets avec le portail, et à défaut la première interface venue. Sur Tailscale, les adresses des machines (`100.x.y.z`, plage `100.64.0.0/10`) ne partagent pas ce préfixe avec le portail : l'installeur serait retombé sur une interface quelconque (`docker0`, réseau local), et etcd et Patroni se seraient annoncés sur une adresse injoignable pour les autres machines. L'installeur Windows retenait l'adresse au plus long préfixe : Tailscale (`/32`) l'emportait, par chance. Les deux installeurs prennent désormais **l'adresse source de la route vers le portail** (`ip -4 route get`, `Find-NetRoute`), qui est par construction l'interface par laquelle les machines de la PME se joignent, en réseau local comme sur Tailscale. L'ancienne détection reste en repli.

Chaîne vérifiée côté éditeur.

Étape	Résultat
Stack de développement	Redémarrée : PostgreSQL et etcd du portail s'étaient arrêtés avec Docker Desktop, le backend redémarrait en boucle
`RELAY_URL`	`http://100.65.0.5:8080` (`.env` sans BOM) ; backend reconstruit pour servir les installeurs corrigés
Image	`ha-lab/application-exemple` construite et poussée : `localhost:5000/editeurs/exemple-compteur:1.0`, digest `sha256:0f483d31…`
Catalogue	« Compteur (exemple) » 1.0 créé, puis **validé contre le vrai registre** (200) : premier contrôle réel, il n'avait été testé qu'avec des réponses simulées
Licence	Application rattachée à la licence d'AMANE Test
Pile serveur	Téléchargée par `100.65.0.5:8000` avec le jeton du tenant : toutes les images viennent de `100.65.0.5:5000` et sont épinglées par digest ; service `amane-application` sur le réseau `internal`, avec HAProxy et le nœud pour seuls voisins ; modèle de `DATABASE_URL` transmis au lanceur ; relais en `100.65.0.5`
Pile témoin	Sans application
Installeurs	Les quatre (Windows et Linux, serveur et témoin) pointent portail, relais et registre sur `100.65.0.5` ; le bloc de détection d'adresse de l'installeur Windows, exécuté tel quel, donne `100.65.0.5` ; celui de Linux, dans un conteneur, donne l'interface de la route
Joignabilité	Portail, registre (`/v2/`) et relais (`/health`) répondent sur `100.65.0.5` depuis le poste éditeur ; à confirmer depuis un poste du banc (pare-feu Windows de l'éditeur)

Vérifications. Django : 118 tests réussis, dont la détection d'adresse par la route dans les deux installeurs (serveur et témoin).

Ce que l'application de l'équipe doit respecter pour entrer dans AMANE sans modification :

- un seul conteneur, qui sert une interface HTTP sur un port fixe et répond sur un chemin de santé ;
- PostgreSQL seulement, lu depuis une variable d'environnement (par exemple `DATABASE_URL`) ; l'application crée ses tables elle-même au démarrage ;
- aucun accès à Internet pendant le fonctionnement (pas de CDN, de police distante, d'API externe ni de vérification de licence en ligne) ;
- pas de WebSocket ;
- des chemins relatifs, ou qui supportent un relais (`X-Forwarded-*`), puisque l'interface est servie par le nœud sur le port 9001 ;
- les fichiers à conserver dans des dossiers déclarés comme volumes ;
- une commande de démarrage connue, à reporter dans le manifeste.

Risques propres à Tailscale, à observer sur le banc. Docker Desktop doit joindre les adresses `100.x` depuis ses conteneurs (etcd, Patroni) et son démon (registre) ; le pare-feu Windows du poste éditeur doit laisser entrer 8000, 5000 et 8080 par l'interface Tailscale ; les délais de bascule mesurés passeront par un réseau chiffré plutôt qu'un réseau local.

Faille corrigée le 2026-11-04 — l'application hébergée lisait les secrets du cluster

Constat. En rédigeant la procédure de test sur 5 machines (test de confinement G3), il est apparu que le conteneur `amane-application` montait **tout le volume** `secrets` de la machine, en lecture seule. Ce volume contient `postgresql.env`, écrit en mode 0644 par l'orchestrateur : mot de passe du superutilisateur PostgreSQL (`PGPASSWORD_SUPERUSER`), de la réplication, du rôle `amane` du nœud et de pgAdmin. Le lanceur n'avait besoin que de `application.env`.

Gravité. Élevée : la promesse d'ADR-003 et d'ADR-008 (« le code de l'éditeur tiers est confiné ») ne tenait pas. Le réseau de l'application est sans sortie, mais HAProxy y est attaché et mène au primaire PostgreSQL. Une application malveillante ou compromise pouvait donc :

- se connecter en superutilisateur et lire ou modifier la base `amane` du nœud (comptes de la console, journal) ;
- exécuter des commandes dans le conteneur PostgreSQL (`COPY … TO PROGRAM`, réservé au superutilisateur). Ce conteneur est sur le réseau `amane`, qui a une sortie : c'était une voie d'évasion du confinement réseau ;
- remplacer le mot de passe de réplication ou celui du rôle `amane` et perturber le cluster.

Aucune PME n'était exposée : la V3 n'est installée sur aucune machine réelle.

Correction.

Élément	Avant	Après
Identifiants de l'application	`/amane/secrets/application.env`, dans le volume du cluster	`/amane/secrets-application/application.env`, dans un volume dédié `secrets-application`

Élément	Avant	Après
Volumes de `amane-application`	`secrets:/amane/secrets:ro` (tout le cluster)	`secrets-application:/amane/secrets-application:ro` (ses seuls identifiants)
Accès en écriture au nouveau volume	—	`amane-init` (prépare le dossier pour l'uid de l'orchestrateur) et `amane-orchestrateur` (écrit le fichier) ; aucun autre service ne le monte
Orchestrateur	—	`init -dossier-secrets-application` (`cmd/orchestrator/pme.go`) ; chemin par défaut du lanceur mis à jour (`lancer.go`)
Pile sans application ou sans base	Inchangée	Inchangée : le volume n'existe que si l'application a une base

Options écartées : rendre `postgresql.env` illisible par un autre utilisateur (mode 0600) ; l'application peut tourner en root dans son image, et ce mode ne la protégerait donc pas. Retirer le superutilisateur de la portée de HAProxy (`pg_hba`) : utile en défense en profondeur, mais sans effet sur les autres mots de passe du fichier. Ce point reste à étudier (§ 7).

Vérifications.

- Django : 120 tests réussis, dont un nouveau test. Il vérifie que l'application ne monte aucun volume `secrets` et monte `secrets-application` en lecture seule, que seuls l'amorçage et l'orchestrateur écrivent dans ce volume, et que la pile sans base n'en a pas.
- Go : `cmd/orchestrator`, `bootstrap` et `lanceur` réussis, dont un nouveau test de préparation du dossier par `init`.
- Docker réel, avec l'image publiée : `init` prépare `/amane/secrets-application` pour l'uid 10001 de l'orchestrateur ; l'orchestrateur y écrit ; un autre utilisateur, en lecture seule, n'y voit que `application.env`.
- Pile servie au tenant AMANE Test : application sur `secrets-application` en lecture seule, orchestrateur `c15cef0b…`.
- Images : orchestrateur reconstruit et pile republiée (`scripts/publier-pile.sh localhost:5000`) ; les cinq autres digests sont inchangés.

Incident pendant la vérification. Lancés sur le poste de développement sans `AMANE_TEST_ETCD`, les tests Go de l'orchestrateur ont joint l'etcd de la stack compose. En cause, `TestCmdInitPairsDuPortailInjoignables` : il annonçait un pair en `127.0.0.1`, dont l'amorçage déduisait `127.0.0.1:2379`, l'etcd du portail. L'amorçage s'y est fait ajouter comme membre fictif (`192.168.1.10`). Avec un membre injoignable sur deux, etcd a perdu son quorum, et Patroni a passé les deux PostgreSQL du portail en lecture seule. C'est aussi ce qui expliquait un premier échec intermittent de la suite.

Réparation :

1. sauvegarde du volume etcd ;
2. un redémarrage d'etcd avec `--force-new-cluster`, qui garde les données et revient à un seul membre ;
3. réélection du primaire Patroni.

Le test annonce désormais `192.0.2.1` (RFC 5737, jamais routée).

Procédure de test. La procédure sur 5 machines a été rédigée (doc Claude « AMANE V3 — Procédure de test sur 5 machines »). Elle comprend :

- quatre paliers : 2 serveurs + témoin, puis 3 serveurs, puis refus de licence, puis 4 serveurs + témoin ;
- la fiche « préparer son SaaS pour AMANE » destinée à l'équipe ;
- une grille de suivi.

Le test G3 y vérifie cette correction.

Étape 8 — Récupération de la DEK après perte totale (2026-11-04)

Décisions. ADR-010. L'utilisateur a choisi : deux facteurs (passphrase du gérant **et** deux parts papier sur trois), la bibliothèque vsss-rs pour le partage de Shamir, et un garde-fou qui contraint l'installation sans jamais bloquer l'activité.

Ce qui a été fait.

Domaine	Fichiers	Contenu
Socle	`ss-crypto/src/shamir.rs`, `recovery.rs`, `Cargo.toml`	Arithmétique GF(256) maison retirée : partage par vsss-rs 6.0.1 (`split_secret`, `reconstruct_secret`, seuil et nombre réglables). `deriver_kek` (BLAKE2b-256 à clé), `paire_de_recuperation` (X25519), `empreinte_dek`, `somme_controle_part`, paramètres Argon2id de RFC 9106 conservés dans le blob. vsss-rs suit rand_core 0.10 : l'aléa du système lui est fourni par `getrandom` 0.4
Nœud	`spike/node/src/recuperation.rs`	Blob binaire de 119 octets (version, sel, paramètres, empreinte, DEK scellée) ; parts et bloc en base32 par groupes de 4 avec somme de contrôle liée au jeu ; table `recuperation` de la base `amane` (configurée ou reportée, par qui, quand, clé publique) ; dépôt et lecture sur le relais (clé `recuperation`) ; garde des sauvegardes ; republication
Console du nœud	`auth/routes.rs`, `web.rs`	Page `/amane/admin/recuperation` : passphrase saisie deux fois (12 caractères au moins), Argon2id hors de la boucle asynchrone, trois feuilles imprimables (une part chacune, le bloc, la marche à suivre) affichées une seule fois ; bouton « Plus tard » consigné ; premier login administrateur redirigé tant que rien n'est fait ; bandeau « Installation incomplète » ; lien dans la barre latérale
Commande	`cmd/recuperer.rs`, `main.rs`	`ss-node recuperer [--bloc]` : blob lu sur le relais ou bloc imprimé ressaisi, passphrase masquée au terminal, parts redemandées en cas de faute de frappe ; la DEK récupérée remplace la DEK neuve, scellée pour la machine, et le journal local chiffré par la DEK neuve est mis de côté
Supervision	`cmd/run.rs`	Le primaire ne sauvegarde pas si le relais protège une autre DEK ; après chaque sauvegarde, le blob est rescellé et redéposé ; l'état de la récupération est lu chaque minute et joint au battement de cœur

Domaine	Fichiers	Contenu
Portail	`devices` (migration 0010), `tenants/models.py`, `api_espace.py`	`Device.recuperation` (`configuree`, `reportee`, `non_configuree`, `dek_differente`) ; `etat_recuperation` de l'espace PME, pire état des serveurs actifs (témoins exclus)
Console React	`EtatsNoeud.tsx`, `MonEspacePage.tsx`, `ArchitecturePage.tsx`, `types/index.ts`	Pastille « Récupération » sur chaque serveur ; alerte « Installation incomplète » ou « Récupération en attente : sauvegardes suspendues » dans l'espace PME ; hiérarchie des clés à jour
Documentation	`CONTRAT-API.md`, `ACCES-INTERFACES.md`, `Architecture_SaaS_Souverain_Trois_Acteurs.md`, `CLAUDE.md`	Champs, page, commande et parcours de récupération ; les mentions « pas encore branché » sont retirées

Défauts trouvés en cours de route.

- **Régression de la sauvegarde de l'application** (`ac4e022`). Introduite par la correction de la faille des secrets (`5646992`) : le nœud décidait de sauvegarder la base `application` d'après la présence de `/amane/secrets/application.env`, déplacé dans le volume dédié qu'il ne monte pas. La pile lui annonce désormais la base par `AMANE_APP_BASE`, et un test Rust ainsi qu'un test Django le vérifient.
- **Une erreur dans l'ADR, corrigée avant la publication.** Il était écrit que reconfigurer la récupération invalide les anciennes feuilles. C'est faux : leur bloc imprimé contient la même DEK, scellée sous l'ancienne clé. La console et l'ADR demandent désormais de détruire les anciennes feuilles. Seule une rotation de la DEK, non prévue, les rendrait inutilisables (§ 7).

Vérifications.

- `ss-crypto` : 29 tests réussis, dont le parcours complet (passphrase et deux parts quelconques), les refus (mauvaise passphrase, parts d'un autre jeu, une seule part, part en double) et un partage 3 sur 5.
- Nœud : 36 tests réussis, dont 7 pour la récupération : aller-retour du blob, saisie tolérante mais contrôlée, rescellement, refus d'une passphrase courte, aucune donnée secrète dans le blob. Le reste de l'espace de travail `spike` et le SDK `core-rust` passent aussi.
- Django : 124 tests réussis, dont 4 sur l'état de la récupération (enregistrement, mise à jour, refus d'une valeur invalide, pire état du cluster, témoin exclu). Console React : `tsc`, `eslint` et `vite build` réussis.
- **Essai de bout en bout** avec l'image du nœud reconstruite, PostgreSQL 17 et le relais du poste éditeur, scénario par scénario :

Scénario	Vérification	Résultat
Installation	Premier login administrateur redirigé vers `/amane/admin/recuperation` ; bandeau « Installation incomplète »	Réussi
Configuration	Passphrase courte refusée ; trois feuilles affichées ; blob de 119 octets déposé sur le relais, sans la passphrase ni une part ; bandeau et redirection disparus ; état « configurée » suivi par le nœud	Réussi
Perte totale	Conteneurs et base supprimés, nœud réinstallé avec une DEK neuve : la garde détecte que le relais protège une autre DEK	Réussi
Reconstitution	Faute de frappe détectée par la somme de contrôle ; mauvaise passphrase refusée ; DEK récupérée avec les parts 3 et 1 ; journal de la DEK neuve mis de côté ; après redémarrage, la DEK est celle que protège le relais	Réussi
Sans relais	DEK récupérée sur un troisième nœud depuis le bloc imprimé et les parts 2 et 3	Réussi

Bilan : 16 vérifications sur 16. Non rejoué dans cet essai : la restauration des bases après récupération, qui passe par HAProxy et le superutilisateur de la pile complète. Elle utilise le même chemin que l'essai de l'étape 4, avec la DEK d'origine, et sera vérifiée sur le banc (test R4). Images republiées : nœud `307b8192…`, orchestrateur `4186b1b7…` (reconstruit par le script de publication, sans changement de code).

Étape 9 — Jeton du relais et sauvegardes liées à leur nom (2026-11-05)

Préalable. Les six commits locaux du 2026-11-04 (installeurs, faille des secrets, régression de la sauvegarde, étape 8, journal v2.5 à v2.7) ont été poussés sur `origin/main3` (`6e2281d..4e7d640`) à la demande de l'utilisateur, qui a demandé dans le même message de passer à l'étape 9.

Décisions. ADR-011, correctif proposé le 29/10 et mis en œuvre tel quel ; décisions de détail (portée, remise par la pile, refus de démarrer, format de l'en-tête, anciens blobs) prises pour le réaliser et consignées dans l'ADR.

Ce qui a été fait.

Domaine	Fichiers	Contenu
Socle	`ss-crypto/src/jeton_relais.rs`, `dek.rs`, `Cargo.toml`	`jeton_relais` et `verifier_jeton_relais` (HMAC-SHA256, RustCrypto, comparaison en temps constant) ; `Dek::encrypt_avec_contexte` et `decrypt_avec_contexte` (données associées de XChaCha20-Poly1305)
Relais	`spike/relay/src/main.rs`, `Cargo.toml`, `Dockerfile`	Secret et dossier des blobs lus une fois au démarrage et gardés dans l'état ; jeton du tenant exigé sur les blobs et la topologie ; refus de démarrer sans secret, mode ouvert explicite ; `authentification` dans `/health`. Image construite avec Rust 1.88, que `ss-crypto` exige depuis vsss-rs
Nœud	`relay_client.rs`, `sauvegarde.rs`, `recuperation.rs`, `cmd/run.rs`, `cmd/delist.rs`, `cmd/sauvegarder.rs`	Un seul point de lecture du jeton (`RELAY_AUTH_TOKEN`) et d'ajout de l'en-tête, pour les sauvegardes, le blob de récupération et la topologie (l'annonce ne l'envoyait pas) ; en-tête de sauvegarde authentifié ; `ss-node restaurer` vérifie le nom et affiche la date de la sauvegarde
Portail	`tenants/relais.py`, `services.py`, `config/settings.py`, `dashboard/relay.py`, `.env.example`	`RELAY_SECRET` ; jeton calculé pour la pile serveur ; la page Relais lit la topologie de chaque tenant avec son jeton ; sans secret, avertissement unique dans les journaux et piles sans jeton
Pile	`templates/tenants/docker-compose.yml.tmpl`	`RELAY_AUTH_TOKEN` du service `ss-node`, fixé par le portail
Déploiement	`relay-deploy/` (`.env.example`, `docker-compose.yml`, `setup.sh`), `spike/docker-compose.yml`	`RELAY_SECRET` à la place de `RELAY_AUTH_TOKEN`, généré par `setup.sh` ; laboratoire en mode ouvert explicite
Documentation	`ACCES-INTERFACES.md`, `CLAUDE.md`	Jeton exigé sur chaque route du relais, calcul, variables

Vérifications.

- `ss-crypto` : 32 tests réussis, dont le vecteur commun avec le portail, le refus du jeton d'un autre tenant, d'un autre secret, tronqué ou mal formé, et le refus d'un chiffré déchiffré avec un autre contexte.

- Relais : 7 tests réussis : dépôt, relecture et suppression avec le jeton ; sans jeton, avec un jeton faux ou avec le jeton valide d'un autre tenant, ni lecture, ni écrasement, ni suppression (9 combinaisons) ; topologie réservée au tenant ; mode ouvert explicite ; refus de démarrer sans secret ou avec un secret court.
- Nœud : 39 tests réussis, dont 4 sur le format des sauvegardes : aller-retour, blob déplacé sous le nom d'un autre jour, d'une autre base ou d'un autre tenant refusé, en-tête falsifié refusé au déchiffrement, ancien format refusé. Le SDK `core-rust` compile et passe ses tests avec le nouveau socle.
- Django : 128 tests réussis, dont 4 nouveaux : vecteur commun avec le relais, jeton dans la seule pile serveur (ni le secret ni le jeton d'enregistrement n'y figurent), pile sans jeton sans secret, topologie lue par la page Relais avec le jeton du tenant.
- **Essai réel du relais** (binaire compilé, lancé en conteneur sur le port 8089, à côté du relais du banc ; secret aléatoire ; jetons calculés par `tenants/relais.py`) : sans `RELAY_SECRET`, refus de démarrer (code 2) ; avec, `/health` indique `authentification: true` ; dépôt et relecture avec le jeton du tenant : 200 ; lecture sans jeton, suppression avec le jeton d'un autre tenant : 401 ; annonce sans jeton : 401, avec : 200 ; topologie avec le jeton d'un autre tenant : 401, avec le sien : 200. Le portail et le relais calculent donc bien le même jeton.
- **Image Docker du relais non construite.** Docker Desktop a redémarré au début de la construction (les conteneurs PostgreSQL et etcd du portail se sont arrêtés avec lui, comme le 4 novembre) ; la construction sans cache a été abandonnée au profit de l'essai ci-dessus. Le passage du `Dockerfile` à Rust 1.88 sera vérifié à l'étape 10.

À faire à l'étape 10. Le relais du poste éditeur tourne encore sur l'image du 29/10, ouverte. Reconstruit, il refusera de démarrer tant que `RELAY_SECRET` ne lui est pas donné : générer le secret, le placer dans l'environnement du relais **et** dans le `.env` du portail (puis reconstruire le backend), reconstruire et republier le nœud, puis retélécharger la pile des machines déjà installées pour leur remettre leur jeton.

7. Points ouverts

Sujet	Question	Lié à
Rotation de la DEK	Aucune rotation n'est prévue : d'anciennes feuilles de récupération, d'anciens serveurs retirés et d'anciennes sauvegardes gardent la même DEK. La rotation exige de rechiffrer les sauvegardes du relais et de resceller pour chaque serveur ; la clé publique de récupération permet déjà de republier le blob sans la passphrase	ADR-010
Chiffrement au repos	Tranché par ADR-008 (chiffrement du disque vérifié). À rouvrir si une PME exige un chiffrement sous la DEK indépendant de son système	ADR-008
Licence du SaaS externe	Comment l'application vérifie-t-elle sa propre licence sans accès sortant vers son éditeur ? Relais de métadonnées par le nœud ?	ADR-003
Mises à jour de l'application	Une nouvelle version est validée par l'éditeur AMANE (ADR-009) ; reste : signature des images (cosign) en plus du digest, et propagation aux machines installées (régénération de la pile aujourd'hui)	ADR-002, ADR-009
Authentification utilisateur	Le reverse proxy ajoute-t-il un contrôle d'appareil appairé devant l'interface, ou laisse-t-on uniquement le login de l'application ?	ADR-003
Applications multi-conteneurs	Un SaaS peut nécessiter plusieurs services (web, worker, cache) : le manifeste doit-il décrire un ensemble ? Une licence ne rattache qu'une application	ADR-002, ADR-009
Bases autres que PostgreSQL	Que faire d'une application qui exige MySQL ou MongoDB ?	ADR-001
Délais de bascule sur le banc	Confirmer sur machines réelles les cibles d'ADR-006 (laboratoire : crash < 5 s, machine ≈ 5 s, partition < 8 s)	ADR-006, banc
Validation sur le banc	Installer AMANE Test (2 serveurs + témoin) selon l'annexe ; vérifier pare-feu Windows et Docker Desktop	Étape 2b
Essai de bout en bout de l'étape 3	Rejouer l'essai sur trois machines avec l'application d'exemple (interrompu faute de mémoire), en y ajoutant l'enrôlement et une sauvegarde	Étapes 3, 4
Console React non parcourue	Les pages des étapes 5 et 6 ont été vérifiées par compilation, lint et build, pas dans un navigateur contre un portail réel	Étape 6, banc
WebSockets	Le relais du nœud ne relaie pas encore les connexions WebSocket	ADR-007
Enrôlement sur un réseau hostile	L'échange d'enrôlement passe en HTTP sur le réseau local : la DEK y est scellée, mais un attaquant placé au milieu pourrait capter le code et substituer sa clé publique, ou remettre une fausse DEK. Piste : afficher l'empreinte de la clé du nouveau serveur dans la console pour confirmation humaine, ou TLS du mesh	ADR-008

Sujet	Question	Lié à
Mesh WireGuard	Reporté au-delà de l'étape 7 ; à valider sur le banc (`NET_ADMIN`, Docker Desktop)	ADR-008
Taille des sauvegardes	L'export est chiffré en mémoire en un seul bloc (limite pratique : quelques centaines de Mo). Au-delà : chiffrement par morceaux en flux	ADR-008
Renouvellement du jeton d'un tenant	Le jeton dérive du seul secret commun : en cas de fuite du jeton d'un tenant, le renouveler oblige à changer le secret et à retélécharger la pile de tous les tenants. Piste : un compteur de génération par tenant inclus dans le HMAC, incrémenté par le portail	ADR-011
Relais à secret unique	Le secret commun est la clé de tous les jetons : sa fuite côté portail ou relais rouvre l'accès aux blobs (toujours chiffrés) de tous les tenants. Le garder hors du dépôt, dans les `.env` du portail et du relais	ADR-011
Refus de licence sans effet sur le cluster	Un serveur au-delà du nombre de postes est refusé et désactivé par le portail (`devices/api_register.py`), mais ni le nœud ni l'orchestrateur n'agissent sur ce refus : l'amorçage le fait entrer dans etcd et Patroni, et il sert l'application. À confirmer sur le banc (test E1), puis faire respecter le refus par l'amorçage	Licences, ADR-005
Superutilisateur joignable depuis le réseau de l'application	HAProxy, attaché au réseau de l'application, mène au primaire pour tous les rôles. Défense en profondeur : restreindre par `pg_hba` le réseau de l'application au seul rôle `application`	ADR-008
Sauvegarde sur un serveur non enrôlé	Un primaire sans DEK ne sauvegarde pas (il le signale dans ses journaux). Alerter le portail ?	ADR-008
Vulnérabilités préexistantes	`govulncheck` signale 12 vulnérabilités atteignables antérieures à 2b : bibliothèque standard (toolchain 1.27.0), `golang.org/x/net`, `google.golang.org/grpc`	Commit de mise à jour dédié
Couverture Go globale	68,2 % (68,9 % avant 2b), sous le seuil CI de 70 % depuis avant la refonte : `main()` de l'orchestrateur et `wgmesh` ne sont pas testés	CI
Filtres de chemins de `chaos-tests.yml`	Le workflow surveille `consensus/**`, `supervisor/**`… à la racine, alors que ces dossiers sont sous `orchestrator-go/` : il ne se déclenche jamais sur une PR	CI

Annexe — Mettre à jour ce document

1. Modifier la source `docs/refonte-v3/AMANE-Refonte-V3.md` : statut des étapes (§ 5), entrée dans le journal (§ 6), nouvelle ADR (§ 3) ou point ouvert (§ 7).
2. Incrémenter la version dans l'en-tête et ajouter une ligne à l'historique des versions.
3. Régénérer le PDF : `python docs/refonte-v3/generer_pdf.py` (dépendance : `reportlab`).
4. Commiter la source et le PDF ensemble, par exemple `docs(refonte): étape 1 — nettoyage`.

Annexe — Validation sur le banc AMANE Test (étapes 2b à 4)

Objectif : installer le banc **AMANE Test** (3 postes) en 2 serveurs + 1 témoin avec la pile générée, puis vérifier la bascule réelle.

Côté éditeur (portail).

1. Démarrer la pile de développement (`docker compose up -d`) : portail, registre local (port 5000).
2. Construire l'image du nœud (`spike\build-node.ps1`), puis publier la pile : `bash scripts/publier-pile.sh localhost:5000`. Vérifier que `media/node-images/pile.json` liste six images `@sha256:`.
3. Relais démarré avec `RELAY_SECRET`, le même que dans le `.env` du portail : `/health` doit répondre `"authentification": true` (ADR-011).
4. Dans la console, **désactiver les anciennes machines** du tenant AMANE Test. Sinon l'amorçage verrait des machines connues mais injoignables et refuserait, à juste titre, de créer un cluster.

Côté PME (les trois postes).

5. Depuis l'espace PME du tenant, télécharger l'installeur **serveur** et le lancer en administrateur sur le poste 1. Noter le mot de passe pgAdmin affiché à la fin.
6. Lancer l'installeur **serveur** sur le poste 2 ; il doit annoncer « 1 serveur(s) déjà installé(s) ». Puis l'**enrôler** (étape 4) : dans la console du poste 1 (`http://<poste 1>:9001/amane/admin/enrolement`), générer un code, et sur le poste 2 lancer `docker exec ss-node ss-node enroler --depuis http://<poste 1>:9001 --code <code>` puis `docker restart ss-node`.
7. L'espace PME doit alors proposer un témoin : télécharger l'installeur **témoin** et le lancer sur le poste 3.

Vérifications.

8. Sur un serveur : `docker exec amane-postgresql patronictl list` → un `Leader` et un `Sync Standby` en `streaming`, nommés d'après les postes.
9. `docker exec amane-etcd etcdctl member list` → 3 membres `started`.
10. Console éditeur : 2 serveurs et 1 témoin actifs ; la licence ne compte que les 2 serveurs.
11. Bascule : éteindre brutalement le poste du primaire (alimentation) ; sur l'autre serveur, `patronictl list` doit le montrer `Leader` en quelques secondes ; pgAdmin (port 5050) doit pouvoir écrire.
12. Rallumer le poste : il doit revenir en `Replica` puis `Sync Standby`.
13. Sauvegarde : `docker exec ss-node ss-node sauvegarder` sur le primaire ; le blob doit apparaître sur le relais (page Relais de la console), commencer par l'en-tête `amane-sauvegarde/1` et ne contenir aucune autre donnée lisible. Une requête sans jeton (`curl http://<relais>:8080/api/blobs/<tenant>/sauvegarde-amane-<jour>`) doit répondre 401.
14. Console éditeur : la page Appareils doit montrer l'état du disque de chaque poste (chiffré ou non) et le témoin.

Application hébergée, récupération (après les étapes 8 et 9).

15 Application d'exemple : la page répond par `http://<poste 1>:9001/` et par `http://<poste 2>:9001/` ; un compteur incrémenté par l'un est relu identique par l'autre ; après l'extinction du primaire, l'application répond toujours par le serveur restant et le compteur est intact.

16 Récupération configurée sur le poste 1 (passphrase du gérant, parts imprimées) ; le blob de récupération apparaît sur le relais.

17 Perte totale simulée : les deux serveurs sont réinstallés à neuf ; `ss-node recuperer` avec la passphrase et deux parts ; `ss-node restaurer` rend les données d'avant la perte.

Consigner les résultats et les durées dans le § 6 (étape 2d pour les mesures fines).